

Question 1 of 82

For which purpose would a security analyst use mbtget?

- ☐ To send commands to test a PROFIBUS device
- ☐ To enumerate HTTP traffic on a web-enabled HMI
- ☐ To discover weak session management on a web application
- ☐ To interact with the modbus-tcp protocol

全82問中1問目

セキュリティアナリストはどのような目的でmbtgetを使用するのでしょうか？

- ☐ PROFIBUSデバイスをテストするためのコマンドを送信する
- ☐ Web対応HMI上のHTTPトラフィックを列挙する
- ☐ Webアプリケーションにおける脆弱なセッション管理を発見する
- ☒ modbus-tcpプロトコルとやり取りするには

✔ その通りです

mbtgetは、最も一般的に使用されているTCP/IPベースのICSプロトコルの1つであるmodbus-tcpプロトコルと連携できます。mbtgetのようなツールを使用すると、攻撃者は実行中のICSプロセスを変更するmodbusコマンドを簡単に作成でき、プロセスを停止させたり、さらに悪いことに、プロセスを実行している企業やエンジニアに最大限の影響を与えるようにICSプロセスを改変したりすることができます。

Question 2 of 82

When a HMI panel displays an alarm from a device's tamper sensor, which type of physical security control does it indicate?

- ☐ Deterrence
- ☐ Response
- ☐ Prevention
- ☐ Detection

全82問中2問目

HMIパネルにデバイスの改ざんセンサーからのアラームが表示された場合、それはどのようなタイプの物理的セキュリティ制御を示しているのでしょうか？

- ☐ 抑止力
- ☐ 応答
- ☐ 防止
- ☒ 検出

✔ その通りです

改ざん検知センサーは、セキュリティ侵害が発生した可能性を検知し、攻撃者を特定できます。物理的な抑止力は攻撃の試みの可能性を低減し、遅延機能は攻撃者の行動を遅らせます。物理的な認証レベルは、許可された担当者のみがエリアにアクセスできるようにする機能であり、対応機能は物理的な防御の最終段階であり、攻撃の結果として担当者と手順を発動します。

Question 3 of 82

Which protocol makes use of CSMA/CD so that multiple devices can communicate on the same Layer 1 medium?

- ☐ Internet Protocol (IP)
- ☐ Profibus
- ☐ Modbus
- ☐ Ethernet

全82問中3問目

複数のデバイスが同じレイヤ1媒体上で通信できるように、CSMA/CDを利用するプロトコルはどれですか？

- ☐ インターネットプロトコル (IP)
- ☐ プロフィバス
- ☐ Modbus
- ☒ イーサネット

✔ その通りです

CSMA/CDは、イーサネットプロトコルにおいてネットワーク上の衝突を検出し、再送信の必要性を示すために使用されます。これにより、同じレイヤ1媒体を使用して複数の通信が可能になります。

Question 4 of 82

Which zone should be used to centralize data and services so they can be shared between zone boundaries?

- ☐ Demilitarized zone
- ☐ Safety zone
- ☐ Enforcement zone
- ☐ Business zone

全82問中4問目

データとサービスをゾーン境界を越えて共有できるように、それらを一元化するにはどのゾーンを使用すべきでしょうか？

- ☒ 非武装地帯
- ☐ 安全区
- ☐ 執行区域
- ☐ ビジネスゾーン

✔ その通りです

DMZは、機能ごとに異なる一連のゾーンを提供し、ゾーン間でサービスやデータを共有できるようにする。

Question 5 of 82

Maintaining the temperature within a specific range while producing chemicals or plastics is an example of which type of ICS process model?

- ☐ Batch
- ☐ Discrete
- ☐ Continuous

全82問中5問目

化学薬品やプラスチックを製造する際に、温度を特定の範囲内に維持することは、どのタイプのICSプロセスモデルの例でしょうか？

- ☐ バッチ
- ☐ 離散
- ☒ 連続

✔ その通りです

ICSの主なプロセスモデルは、離散型、バッチ型、連続型、ハイブリッド型の4つです。離散型モデルでは、指定された量の材料がワークステーション間を単位として移動し、各単位はプロセス全体を通して固有の識別情報を保持します。その一例として、金属プレス加工（ナンバープレート）が挙げられます。バッチ処理では、特定の量の原材料が特定の方法で一定期間混合され、中間製品または最終製品が生成されます。その一例として、接着剤や糊の製造が挙げられます。連続型モデルでは、温度などの変数が一定期間、特定の範囲（一定）に維持されます。このタイプの処理の例としては、化学薬品やプラスチックの製造が挙げられます。

Question 6 of 82

Which type of device is the following configuration setting from?

```
permit tcp host 192.168.3.66 host 10.10.8.71 eq 22
```

- ☐ Network firewall
- ☐ NIDS
- ☐ Application firewall
- ☐ SIEM

全82問中6問目

以下の設定は、どのタイプのデバイスのものですか？

```
permit tcp host 192.168.3.66 host 10.10.8.71 eq 22
```

- ☒ ネットワークファイアウォール
- ☐ NIDS
- ☐ アプリケーションファイアウォール
- ☐ SIEM

✔ その通りです

ネットワークファイアウォールは、IPアドレスとポートに基づいて許可/ブロックの判断を行います。

Question 7 of 82

Which of the following is a concern with VSAT communication?

- ☐ Lack of VPN support
- ☐ Fixed frequency range
- ☐ Distance of communication
- ☐ Severe weather conditions

全82問中7問目

VSAT通信に関して懸念される点は次のうちどれですか？

- ☐ VPNサポートの欠如
- ☐ 固定周波数範囲
- ☐ コミュニケーションの距離
- ☒ 悪天候

✔ その通りです

VSAT（超小型開口端末）は、複数の周波数帯域で動作できます。VSATリンクは、仮想ローカルエリアネットワーク/プライベートネットワークとデータ暗号化（SSL、SSH、PGPなど）をサポートします。VSATアンテナは、中継衛星との適切な位置とアライメントを維持する必要があり、遮るものがない空の視界が必要となるため、悪天候などの物理的な危険が懸念されます。雨や雪などの悪天候下で送受信を行う必要がある場合、RFリンクは劣化します。VSATは、Cバンド（4～8GHz）、Kuバンド（12～18GHz）、Kaバンド（26.5～40GHz）など、複数の周波数帯域で動作できます。

Question 8 of 82

What is an advantage of using virtualization in an ICS environment?

- ☐ Makes system patching and backups easier
- ☐ Works well across different trust zones on a single host
- ☐ Simplifies troubleshooting and monitoring
- ☐ May be safely managed from any zone in the organization

全82問中8問目

ICS環境において仮想化を利用する利点は何ですか？

☒ システムのパッチ適用とバックアップが容易になります

- ☐ 単一ホスト上の異なる信頼ゾーン間でも正常に動作します
- ☐ トラブルシューティングと監視を簡素化します
- ☐ 組織内のどのゾーンからでも安全に管理できます

☒ その通りです

ICS環境における仮想化の利点としては、リソースの統合、冗長性、テストおよびトレーニング環境の構築、パッチ適用とバックアップの管理の容易化などが挙げられます。仮想化は、同一ホスト上の異なる信頼ゾーンにまたがって構築すべきではありません。信頼ゾーンからのみ管理されるべきです。場合によっては、仮想化によってトラブルシューティングやシステム監視の複雑さが増すこともあります。

Question 9 of 82

Which of the following describes an effective policy?

☐ Achievable and measurable directive

☐ Organizational values statement

☐ Best practice based instruction

☐ Risk and compliance based guidance

全82問中9問目

次のうち、効果的な政策を説明しているのはどれですか？

☒ 達成可能かつ測定可能な指示

☐ 組織の価値観に関する声明

☐ ベストプラクティスに基づいた指導

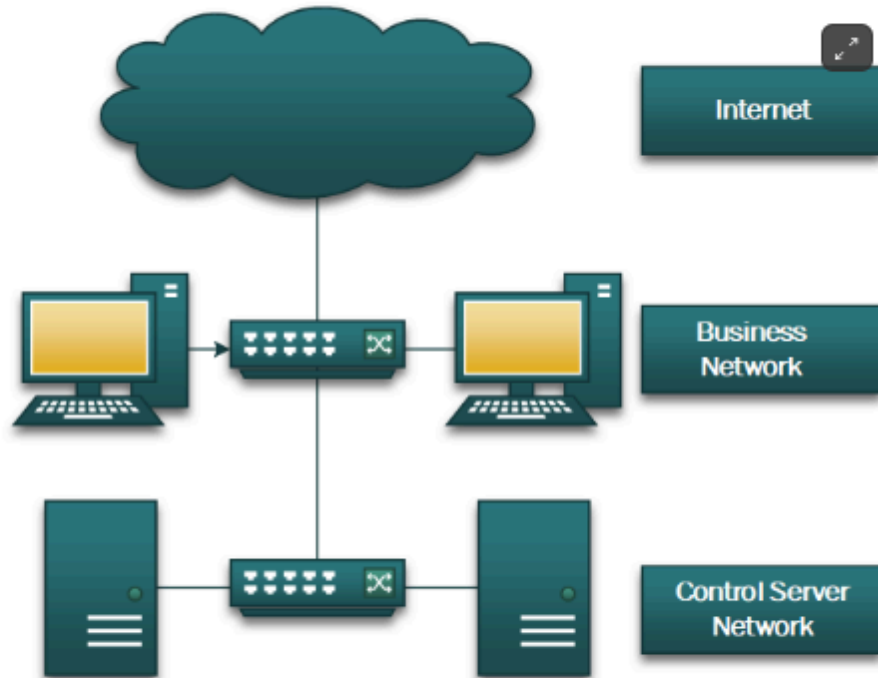
☐ リスクとコンプライアンスに基づくガイダンス

☒ その通りです

政策とは、特定の目標に向かって進むための明確な決定を示す指示である。政策自体は効果的かつ現実的であり、達成可能な安全保障目標を持つべきである。

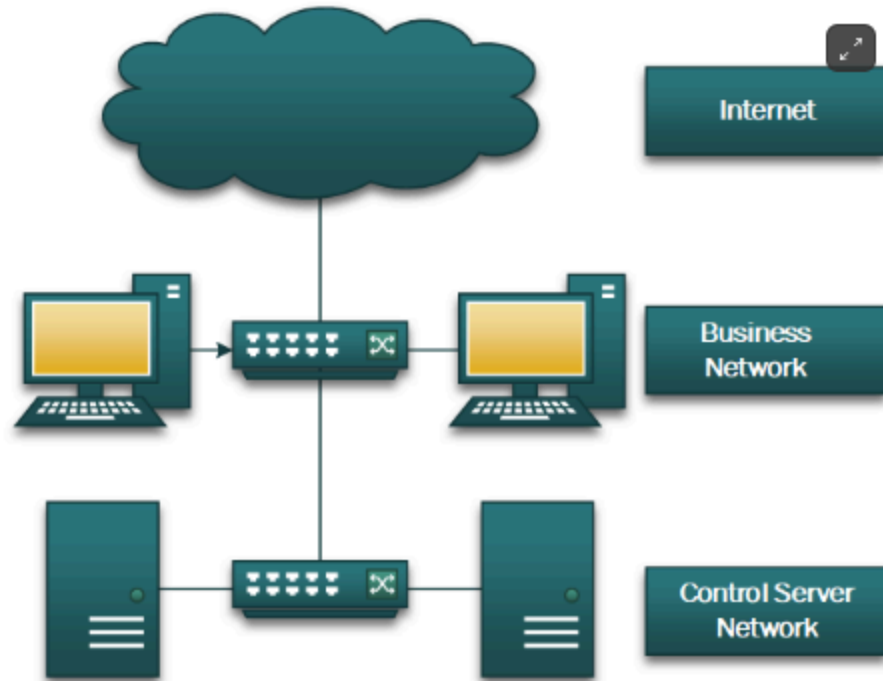
Question 10 of 82

Based on the network shown in the diagram, at minimum how many firewalls should be installed?



- ☐ 5
- ☐ 4
- ☐ 2
- ☐ 3
- ☐ 1

図に示されたネットワーク構成に基づく、最低限いくつのファイアウォールを設置する必要がありますか？



- ☐ 5
- ☐ 4
- ☒ 2
- ☐ 3
- ☐ 1

✔ その通りです

各適用ゾーン間にはファイアウォールを設置し、不要なトラフィックや望ましくないトラフィックがゾーンを通過するのを防ぐ必要があります。図に示すように、これを実現するには、インターネットとビジネスネットワークの間に1つ目のファイアウォールを設置し、ビジネスネットワークと制御サーバーネットワークの間にもう1つのファイアウォールを設置する必要があります。

Question 11 of 82

What is a similarity between the Modbus Remote Terminal Unit (RTU) protocol and the Modbus TCP protocol?

- ☐ Neither supports more than one session at a time
- ☐ Neither uses an IP header
- ☐ Both use a transaction ID
- ☐ Both hex encode the request

Modbusリモートターミナルユニット（RTU）プロトコルとModbus TCPプロトコルの類似点は何ですか？

- ☐ どちらも同時に複数のセッションをサポートしていません
- ☐ どちらもIPヘッダーを使用しない
- ☐ どちらもトランザクションIDを使用します
- ☒ どちらもリクエストを16進数でエンコードします

✔ その通りです

Modbus RTUとModbus TCPはどちらもリクエストを16進数でエンコードします。Modbus RTUは一度に1つのセッションしかサポートしませんが、Modbus TCPは複数の通信を同時に行うことができるため、トランザクションIDを追加します。Modbus RTUはネットワーク層を持たないためIPヘッダーを使用しませんが、Modbus TCPはネットワーク層を使用するためIPヘッダーを追加します。

Question 12 of 82

What information is found in the output of the following command?

```
[tech@archlinux ~]$ df -h
Filesystem      Size  Used Avail Use% Mounted on
dev              1.9G   0  1.9G   0% /dev
run              1.9G  1.6M   1.9G   1% /run
/dev/sda1        20G   13G   5.9G  69% /
tmpfs            1.9G   0   1.9G   0% /dev/shm
tmpfs            1.9G  36K   1.9G   1% /tmp
tmpfs            390M  88K   389M   1% /run/user/1000
```

- ☐ Filesystem types of mounted partitions
- ☐ Disk space utilized by mounted partitions
- ☐ Frequency of use for mounted filesystems
- ☐ Most recently mounted filesystems

全82問中12問目

次のコマンドの出力にはどのような情報が含まれていますか？

```
[tech@archlinux ~]$ df -h
Filesystem      Size  Used Avail Use% Mounted on
dev              1.9G   0    1.9G   0% /dev
run              1.9G  1.6M  1.9G   1% /run
/dev/sda1        20G   13G   5.9G  69% /
tmpfs            1.9G   0    1.9G   0% /dev/shm
tmpfs            1.9G  36K   1.9G   1% /tmp
tmpfs            390M   88K  389M   1% /run/user/1000
```

- ☐ マウントされたパーティションのファイルシステムの種類
- ☒ マウントされたパーティションによって使用されるディスク容量
- ☐ マウントされたファイルシステムの使用頻度
- ☐ 最近マウントされたファイルシステム

☒ その通りです

ここに表示されている出力は、dfLinuxシステム上の`disk free`コマンドの出力です。このコマンドは、ディスクまたはディスクセット上のパーティションの数、名前、サイズ、および使用率を表示するために使用されます。

Question 13 of 82

Which of the following network reconnaissance tools is generally safe to run on a control system network?

- ☐ Nessus
- ☐ Wireshark
- ☐ hping
- ☐ NMAP

全82問中13問目

以下のネットワーク偵察ツールのうち、制御システムネットワーク上で実行しても一般的に安全なものはどれですか？

- ☐ ネットス
- ☒ Wireshark
- ☐ ピン
- ☐ NMAP

☒ その通りです

WiresharkやTCPDumpなどのネットワークスニファは、ポートをまたいでスイッチに安全に接続できるリスニング専用アプリケーションです。一方、NMAP、Nessus、hpingは、ネットワークにトラフィックを注入し、サーバーをアクティブにスキャンするツールです。アクティブアプリケーションは、重要なサービスのクラッシュやサービス拒否攻撃を引き起こす可能性を高めるため、重要な制御システムネットワークを危険にさらします。

Question 14 of 82

A reactor operator at a nuclear power plant can control Pump_A on Unit 1 and Pump_B on Unit 2 from a single, centralized HMI. What level of the Purdue model are the pumps in?

- ☐ Level 1
- ☐ Level 2
- ☐ Level 4
- ☐ Level 3
- ☐ Level 0

全82問中14問目

原子力発電所の原子炉運転員は、単一の中央集中型HMIから、1号機のポンプAと2号機のポンプBを制御できます。これらのポンプは、パーデューモデルのどのレベルに該当しますか？

- ☐ レベル1
- ☒ レベル2
- ☐ レベル4
- ☐ レベル3
- ☒ レベル0

✖ あなたは間違っています

ポンプやバルブなどのコンポーネントは直接的なプロセスの一部であるため、レベル0に分類されます。HMIは工場全体に適用されるため、レベル2ではなくレベル3とみなされますが、これは下位レベルのコントローラーやポンプなどの機器には影響しません。

Question 15 of 82

What can be done to get malicious code to execute when a computer starts up?

- ☐ Inject it into RAM memory
- ☐ Use pagefile.sys to launch it
- ☐ Place it in the boot sector
- ☐ Use the BIOS to launch a script that calls it
- ☐ Use filesystem slack space to store it

全82問中15問目

コンピュータの起動時に悪意のあるコードを実行させるには、どのような方法がありますか？

- ☐ RAMメモリに注入する
- ☐ pagefile.sys を使用して起動します。
- ☒ **ブートセクターに配置してください**
- ☐ BIOSを使用して、それを呼び出すスクリプトを起動します。
- ☐ ファイルシステムの空き領域を使用して保存します。

☒ **その通りです**

BIOSはスクリプトの呼び出しには使用できず、pagefile.sysは物理メモリがいっぱいになった場合にのみアクセスされ、RAMメモリはマシンの電源サイクルごとにクリアされます。また、悪意のあるコードはスラック領域に格納できますが、自動的に起動することはありません。ブートセクタ内のコードは、OSが起動するたびに実行されます。

Question 16 of 82

In what way does EtherNet/IP make use of broadcast UDP messages?

- ☐ To provide device authentication
- ☐ To manage HMI workstations
- ☐ To communicate I/O data
- ☐ To send PLC commands through a router hop

全82問中16問目

EtherNet/IPは、ブロードキャストUDPメッセージをどのように利用しているのでしょうか？

- ☐ デバイス認証を提供する
- ☐ HMIワークステーションを管理する
- ☒ **入出力データを通信するため**
- ☐ ルーターホップを介してPLCコマンドを送信する

☒ **その通りです**

EtherNet/IPは、I/OデータにUDPブロードキャストメッセージを使用します。ブロードキャストは、必要なメッセージ数によっては、ネットワーク上のデバイスに過負荷をかける可能性があります。ネットワークに複数のデバイスが接続されている場合は、マネージドスイッチでIGMPスヌーピングを行うことで、この問題を軽減できます。これはI/Oトラフィックに関する問題であり、ワークステーション/サーバーレベルでは問題になりません。

Question 17 of 82

Which of the following protocols relies on three geostationary I-4 satellites and provides three different types of service?

- ☐ CDMA
- ☐ GSM
- ☐ BGAN
- ☐ VSAT
- ☐ LTE

全82問中17問目

以下のプロトコルのうち、3基の静止軌道I-4衛星を利用し、3種類の異なるサービスを提供するものはどれですか？

- ☐ CDMA
- ☐ GSM
- ☒ BGAN
- ☐ VSAT
- ☐ LTE

✔ その通りです

ブロードバンドグローバルエリアネットワーク（BGAN）はインマルサット社が提供しており、I-4と呼ばれる3基の静止衛星を使用してほぼ全世界をカバーしています。BGAN端末の利点の1つは、消費電力が低いことです（待機時4ワット、パースト送信時22ワット）。これは、待機時または送信時に90～150ワットを消費する衛星アンテナシステムよりもはるかに少ない電力です。

インマルサットが提供するサービスには、以下の3種類があります。

・インマルサットの標準BGANサービスは、インターネット、電話、SMS、ファックス、ISDN、ストリーミングサービスを提供します。

・2012年2月に開始されたBGAN M2Mサービスは、リモートSCADAまたはM2M（マシンツーマシン）機器の監視と制御のための低帯域幅サービスで、2、5、10、20メガバイトの月額サービスプラン（Hughes 9502 BGAN端末）で提供されます。

・2012年3月に開始されたBGAN LinkIは、月間5～30ギガバイトのデータ転送を必要とする固定拠点向けです（クラス1 BGAN端末（Hughes 9201またはExplorer 700/710）でのみ利用可能です）。

Question 18 of 82

A vendor is remotely connected to a client's HMI workstation. The vendor is browsing a popular forum to assist in troubleshooting the HMI. The vendor accidentally clicked on the following hidden link and valve 41234 in the plant closed. What kind of attack was this?

<http://hmi.SillyVendor.com/close?valve=41234>

- ☐ Cross-site scripting
- ☐ Remote file inclusion
- ☐ SQL injection
- ☐ Cross-site request forgery

全82問中18問目

ベンダーが顧客のHMIワークステーションにリモート接続しています。ベンダーはHMIのトラブルシューティングを支援するために、人気のフォーラムを閲覧していました。ベンダーが誤って以下の隠しリンクをクリックしたところ、工場内のバルブ41234が閉じてしまいました。これはどのような種類の攻撃だったのでしょうか？

<http://hmi.SillyVendor.com/close?valve=41234>

- ☒ クロスサイトスクリプティング
- ☐ リモートファイルインクルージョン
- ☐ SQLインジェクション
- ☒ クロスサイトリクエストフォージェリ

✖ あなたは間違っています

これはクロスサイトリクエストフォージェリの一例です。URLによって指示されたアクションは、ベンダーがクライアントのHMIワークステーション上で持つ権限と同じ権限で実行されます。

Question 19 of 82

Which of the following protocols allows an organization to use its existing IPv6 addressing scheme?

- ☐ WirelessHART
- ☐ ISM band
- ☐ Bluetooth
- ☐ ISA100.11a

全82問中19問目

以下のプロトコルのうち、組織が既存のIPv6アドレス体系を使用できるようにするものはどれですか？

☒ **WirelessHART**

☐ ISMバンド

☐ ブルートゥース

☒ **ISA100.11a**

✖ あなたは間違っています

ISA100.11aは、アドレス指定とサブネット化のスケラビリティのためにIPv6を活用しています。WirelessHARTはIPv4をサポートしていますが、IPv6はサポートしていません。

Question 20 of 82

An attacker inputs the data shown below on a web-based HMI. What type of attack are they attempting?

`<script src="eviltest1.js"></script>`

☐ SQLi

☐ XSS

☐ CSRF

☐ LFI

全82問中20問目

攻撃者がウェブベースのHMIに以下のデータを入力します。攻撃者はどのような種類の攻撃を試みているのでしょうか？

`<script src="eviltest1.js"></script>`

☐ SQLインジェクション

☒ **XSS**

☐ CSRF

☐ LFI

✔ その通りです

これはクロスサイトスクリプティング（XSS）攻撃の一例です。開発者がユーザー入力を適切に処理せず、文字数を制限したり、出力をエンコードしてからページに再表示したりしない場合、攻撃者は入力にJavaScriptを追加して、ユーザーのブラウザで実行させることができます。この例では、攻撃者はブラウザにJavaScriptプログラムを実行させようとしています `eviltest.js`。

Question 21 of 82

If a single loss expectancy is equal to \$30,000 with an exposure factor of 30%, what is the value of the asset?

- ☐ \$100,000
- ☐ \$30,000
- ☐ \$10,000
- ☐ \$1,000

全82問中21問目

単一損失期待値が3万ドルで、エクスポージャー係数が30%の場合、資産の価値はいくらですか？

☒ 10万ドル

- ☐ 3万ドル
- ☐ 1万ドル
- ☐ 1,000ドル

☒ その通りです

$SLE = AV * EF$
 $\$30,000 = AV * 30\%$
 $AV = \$30,000 / 30\%$
 $AV = \$100,000$

Question 22 of 82

Which of the following factors increases the system call efficiency of a real-time operating system?

- ☐ The kernel and user space is not likely to be separated
- ☐ The OS is embedded
- ☐ The system denies hardware interrupts
- ☐ The platform is solid state

全82問中22問目

リアルタイムオペレーティングシステムのシステムコール効率を高める要因は次のうちどれですか？

☒ カーネル空間とユーザー空間は分離されない可能性が高い

- ☐ OSは組み込まれています
- ☐ システムはハードウェア割り込みを拒否します
- ☐ プラットフォームはソリッドステートです

☒ その通りです

RTOS上で動作するプロセスは、システムコール効率が高く、割り込みを無効化したり、その他の方法で環境を管理したりすることができます。これは、RTOSシステムではカーネル空間とユーザー空間が分離されていないためです。RTOSではハードウェア割り込みが禁止されているわけではなく、実際にはハードウェア割り込みの処理はRTOSの重要な機能です。システムが組み込みシステムであるという事実だけでは、システムコール効率が必ずしも向上するわけではありません。むしろ、組み込みシステムでRTOSを使用することによって、システムコール効率が向上するのです。

Question 23 of 82

What is a recommended practice for securing a database in an ICS environment?

- ☐ Limit administrative database roles to just domain admins
- ☐ Don't use the same certificate to authenticate client and server connections
- ☐ Use a single table to hold all of the domain values
- ☐ Don't run backend databases on a virtual machine

全82問中23問目

ICS環境におけるデータベースのセキュリティを確保するための推奨される方法は何ですか？

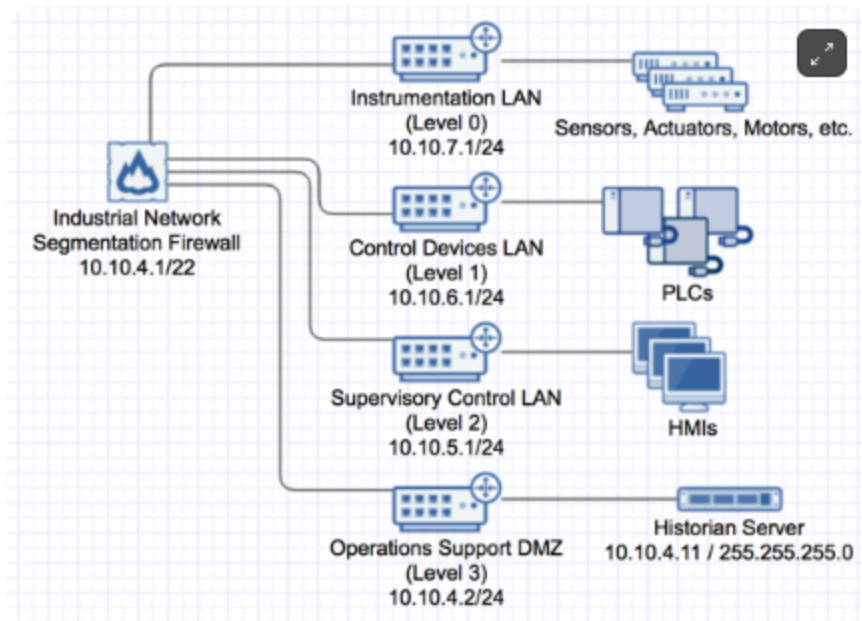
- ☒ 管理データベースの役割をドメイン管理者のみに制限する
- ☒ クライアントとサーバーの接続認証に同じ証明書を使用しないでください。
- ☐ ドメイン値をすべて保持するために単一のテーブルを使用する
- ☐ バックエンドデータベースを仮想マシン上で実行しないでください

✖ あなたは間違っています

データベースを保護するための推奨事項には、クライアント接続とサーバー接続の両方に同じ証明書を使用して暗号化/認証を行わないこと、アプリケーション/データベースのペアごとに固有のユーザー名/パスワードを使用すること、ドメイン管理者ユーザーアカウントを使用しないこと、特にSQLインターフェースにおける安全でない関数呼び出しを制限することなどが含まれます。また、すべてのドメイン値を1つのテーブルに保持することは推奨されません。

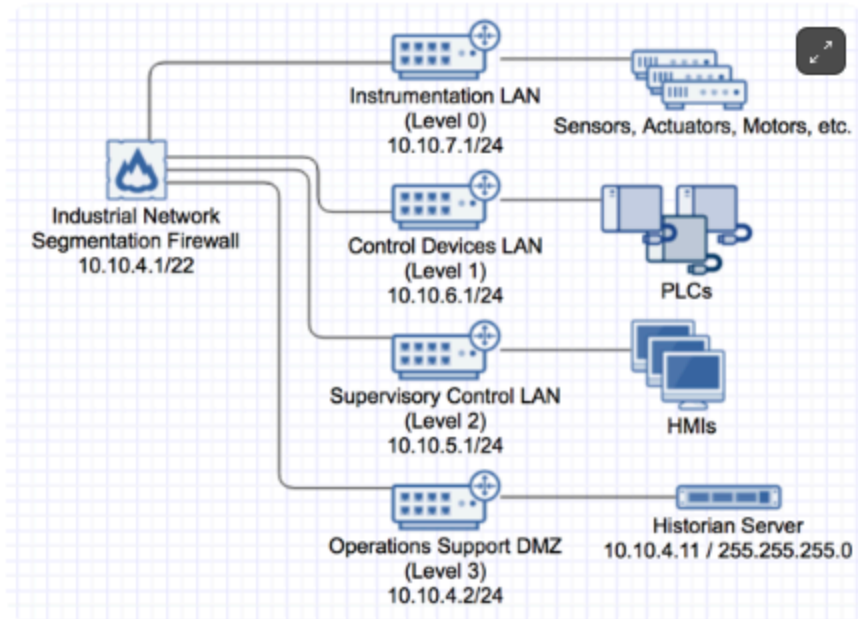
Question 24 of 82

Using the network diagram for context, which of the following source IP addresses would be blocked from connecting to the Instrumentation LAN by an anti-spoofing rule on the firewall?



- ☐ 10.10.5.77
- ☐ 10.10.7.187
- ☐ 10.10.6.24
- ☐ 10.10.4.3

ネットワーク図を参考に、ファイアウォールのなりすまし防止ルールによって計測LANへの接続がブロックされる送信元IPアドレスは次のうちどれですか？



- ☐ 10.10.5.77
- ☒ 10.10.7.187
- ☐ 10.10.6.24
- ☐ 10.10.4.3

✔ その通りです

保護されたネットワークアドレス空間内の送信元アドレスを含む受信パケットはすべて破棄する必要があります。これらのパケットが攻撃者によるアドレスのなりすましによるものか、ルーティングの問題によるものかにかかわらず、受信を許可してはなりません。10.10.4.0/24、10.10.5.0/24、および10.10.6.0/24ネットワークをブロックする理由は他にも考えられますが、なりすましは理由になりません。

Data correlation between devices that are geographically separated by large distances requires which of the following?

- ☐ Very low latency rates between the devices
- ☐ Devices using identical operating systems
- ☐ Accurate timestamps from the I/O devices
- ☐ Devices using a wired 1 Gbps link

全82問中25問目

地理的に大きく離れたデバイス間のデータ相関には、次のうちどれが必要ですか？

- ☒ デバイス間の遅延が非常に低い
- ☐ 同一のオペレーティングシステムを使用するデバイス
- ☒ 入出力デバイスからの正確なタイムスタンプ
- ☐ 有線1Gbpsリンクを使用するデバイス

✖ あなたは間違っています

時間同期は、電力網のような高度に分散したSCADAシステムにおいて非常に重要となる。電力網では、数百マイル離れた機器間や制御センター間でデータを相関させる必要がある場合がある。

Question 26 of 82

Why may a Windows Application log fail to provide information about an application problem?

- ☐ Application logging does not include a field for description
- ☐ The LOGEVENT.EXE process has stopped
- ☐ The application developer did not specify logging information for the problem
- ☐ The server administrator did not enable application logging

全82問中26問目

Windowsアプリケーションログがアプリケーションの問題に関する情報を提供しないのはなぜですか？

- ☐ アプリケーションログには説明欄がありません
- ☐ LOGEVENT.EXE プロセスが停止しました
- ☒ アプリケーション開発者は、この問題に関するログ情報を指定していません。
- ☒ サーバー管理者がアプリケーションログを有効にしていませんでした

✖ あなたは間違っています

アプリケーションログには、開発者が定義および記述した条件が記録されます。開発者が問題のログ記録を選択しなかった場合、アプリケーションログにはエントリが表示されません。サーバー管理者が有効化する必要があるセキュリティログとは異なり、アプリケーションログはデフォルトで実行されます。LOGEVENT.EXE は、管理者が任意のログ情報をログに挿入するために使用できるオプションのコマンドラインツールであり、Windows のイベントログサービスのように自動的に問題をログに記録する機能はありません。アプリケーションログには、他のログと同じイベントフィールドが表示されます。

Question 27 of 82

Which device can be used to prevent a MODBUS write command from being executed on a PLC where only read commands are expected?

- ☐ Packet-filtering firewall
- ☐ Application-layer firewall
- ☐ Network intrusion detection sensor
- ☐ Data diode

全82問中27問目

読み取りコマンドのみが想定されるPLCで、MODBUS書き込みコマンドが実行されないようにするには、どのデバイスを使用すればよいですか？

- ☐ パケットフィルタリングファイアウォール
- ☒ アプリケーション層ファイアウォール
- ☐ ネットワーク侵入検知センサー
- ☐ データダイオード

✔ その通りです

アプリケーションファイアウォール（「次世代ファイアウォール」とも呼ばれる）は、アプリケーションレベルでプロトコルを解釈し、パケットの値と内容に基づいて判断を下すことができます。アプリケーションファイアウォールのルールは、定義された範囲外の値を含むトラフィックを破棄するように設定できます。パケットフィルタリングファイアウォールは、送信元および宛先IPアドレスやポートなど、パケットのネットワーク層およびトランスポート層ヘッダーに含まれる情報に基づいて判断を下します。

Question 28 of 82

When in the recovery stage of an Incident Response, who determines when a system is put back into production?

- ☐ System owner
- ☐ Incident handler
- ☐ Security team
- ☐ Network manager

全82問中28問目

インシデント対応の復旧段階において、システムを本番環境に復帰させるタイミングは誰が決定するのでしょうか？

- ☒ システムオーナー
- ☐ インシデントハンドラー
- ☐ セキュリティチーム
- ☐ ネットワークマネージャー

✔ その通りです

システムをいつ運用再開するかは、システム所有者が決定しなければなりません。担当者は助言や可能な限りのサポートを提供できますが、最終的にシステムをオンラインに戻すかどうかの決定権は、システム所有者または管理者にあります。

Question 29 of 82

Which of the following is a benefit of deploying a centralized SIEM solution?

- ☐ Known attack traffic can be blocked before it reaches vulnerable hosts on the internal network.
- ☐ Vulnerable systems can be updated to current configuration and patch management standards.
- ☐ Events from different systems can be correlated to monitor for trends and anomalies.
- ☐ Archived sensor and safety process data can be stored and accessed long term for performance reporting.

全82問中29問目

集中型SIEMソリューションを導入するメリットは次のうちどれですか？

- ☐ 既知の攻撃トラフィックは、内部ネットワーク上の脆弱なホストに到達する前にブロックすることができる。
- ☒ 脆弱なシステムは、最新の構成およびパッチ管理基準に合わせて更新することができます。
- ☒ 異なるシステムからのイベントを相関させることで、傾向や異常を監視することができる。
- ☐ アーカイブされたセンサーデータと安全プロセスデータは、パフォーマンスレポート作成のために長期保存およびアクセスが可能です。

✖ あなたは間違っています

セキュリティ情報およびイベント管理（SIEM）製品は、一部の組織で、侵入の試みを検出するために、IDSおよびIPSのログ、ならびに他のコンピュータシステム、アプリケーション、インフラストラクチャ機器、その他のハードウェアおよびソフトウェアの監査ログからのイベントを監視、分析、相関付けるために使用されています。

SIEMは、センサーや安全装置などのデータヒストリアンのようなパフォーマンス指標を提供しません。悪意のあるトラフィックをブロックするには、SIEMではなくIPSやファイアウォールを使用します。また、SIEMはネットワークホストの構成管理やパッチ管理も提供しません。

Question 30 of 82

Which of the following Windows event logs would an analyst review to research Windows Service start, stop, and/or failure messages?

- ☐ System
- ☐ Application
- ☐ Security
- ☐ Administrative

全82問中30問目

アナリストがWindowsサービスの開始、停止、および/または失敗メッセージを調査するために確認するWindowsイベントログは次のうちどれですか？

- ☒ システム
- ☐ 応用
- ☐ 安全
- ☐ 管理

☒ その通りです

システムログには、Windowsサービスに関する問題が記録されます。管理者が最初に確認すべき論理的な場所はそこでしょう。

Question 31 of 82

At which NIST Cybersecurity Framework (CSF) Tier is an organization that has approved practices that are not adopted widely throughout the organization?

- ☐ Tier 3 - Repeatable
- ☐ Tier 1 - Partial
- ☐ Tier 4 - Adaptive
- ☐ Tier 2 - Risk Informed

全82問中31問目

組織全体で広く採用されていない承認済みのプラクティスを持つ組織は、NISTサイバーセキュリティフレームワーク（CSF）のどのティアに該当しますか？

- ☐ ティア3 - 繰り返し可能
- ☐ ティア1 - 部分的
- ☐ ティア4 - 適応型
- ☒ ティア2 - リスク情報に基づく

☒ その通りです

ティア2では、リスク管理の実践は経営陣によって承認されているものの、組織全体のポリシーとして確立されていない可能性があります。組織レベルではサイバーセキュリティリスクに対する認識はありますが、サイバーセキュリティリスクを管理するための組織全体のアプローチは確立されていません。

Question 32 of 82

What does the command shown accomplish?

`iptables -F`

- ☐ Resets the table of established connections
- ☐ Displays the existing firewall rules
- ☐ Drops rejected packets without logging
- ☐ Clears existing firewall rules

全82問中32問目

表示されているコマンドは何を実行しますか？

`iptables -F`

- ☐ 確立された接続のテーブルをリセットします
- ☐ 既存のファイアウォールルールを表示します
- ☐ ログを記録せずに拒否されたパケットを破棄する
- ☒ 既存のファイアウォールルールをクリアします

✔ その通りです

「iptables -F」はiptablesのルールをフラッシュします。確立された接続は、明示的に終了されるかタイムアウトするまで維持されます。

Question 33 of 82

A Remote Terminal Unit performs what function?

- ☐ It is a protected instrument system designed to initiate shutdown on a fail safe condition
- ☐ It is a electronic device that interfaces field objects with control or SCADA systems
- ☐ It is a wireless device used to capture and forward IP packets within a mesh network

全82問中33問目

リモート端末装置（RTU）はどのような機能を果たしますか？

- ☐ これは、フェイルセーフ状態時にシャットダウンを開始するように設計された保護された計装システムです。
- ☒ これは、現場の物体と制御システムまたはSCADAシステムを接続する電子機器です。
- ☐ これは、メッシュネットワーク内でIPパケットをキャプチャして転送するために使用される無線デバイスです。

✔ その通りです

リモートターミナルユニット（RTU）は、マイクロプロセッサで制御される電子機器であり、現場にある機器と分散制御システムまたはSCADA（監視制御およびデータ収集）システムとを接続する役割を果たす。

Question 34 of 82

What does the stratum level of a time server indicate about that server?

- ☐ The level of reliability or direct quality of the time server
- ☐ The relative closeness of the server to a high quality time source
- ☐ How vulnerable the server is to machine-in-the-middle attacks
- ☐ How vulnerable the time server is to denial-of-service attacks

タイムサーバーの階層レベルは、そのサーバーについて何を示しているのでしょうか？

- ☒ タイムサーバーの信頼性または直接的な品質レベル
- ☒ サーバーが高品質の時刻ソースにどれだけ近いか
- ☐ サーバーが中間者攻撃に対してどの程度脆弱か
- ☐ タイムサーバーがサービス拒否攻撃に対してどれほど脆弱か

✖ あなたは間違っています

「ストラタム」という用語は、中央または高品質のタイムサーバーまたは基準タイムソースへの相対的な近さを示すために使用されます。このラベリングシステムは、0（より正確で最も近い）から15（精度が低く、最も遠い）までの尺度を使用します。ストラタムレベルは、信頼性や直接的な品質の尺度ではありません。ストラタム2のソースの中には、ストラタム1のソースよりも優先されるものがあります。NTP（タイム）サーバーは、パケットが暗号署名されていない限り、マシンインザミドル攻撃に対して脆弱です。NTPサーバーは、サービス拒否攻撃に対しても脆弱です。

What is a recommendation for setting up a secure ICS network architecture?

- ☐ Limit each Purdue level to having a single subnet in a non-SCADA environment
- ☐ Deploy and manage virtualization technologies in Purdue level 3 separately from that of the enterprise
- ☐ Place workstations having access to the Internet and corporate email at Purdue level 3
- ☐ Place writable aggregate plant historians in the ICS DMZ
- ☐ Put patch management servers for control systems in the ICS DMZ

安全なICSネットワークアーキテクチャを構築するための推奨事項は何ですか？

- ☐ 非SCADA環境では、各パーデューレベルに単一のサブネットのみを持たせるように制限する。
- ☒ Purdueレベル3の仮想化技術を、エンタープライズレベルとは別に展開および管理する。
- ☐ インターネットと社内メールにアクセスできるワークステーションをパデュー大学3階に設置する。
- ☐ 書き込み可能な集合プラント履歴データをICS DMZに配置する
- ☒ 制御システムのパッチ管理サーバーをICS DMZに配置する

✖ あなたは間違っています

パッチサーバーをICS DMZに配置すると、パッチ適用のためDMZファイアウォールに多数の穴を開ける必要が生じます。このため、サーバーをレベル3内に配置することをお勧めします。Purdueレベル3で仮想化技術を使用する場合は、エンタープライズの仮想化技術とは別に展開および管理する必要があります。ネットワークはPurdueレベルごとに編成する必要がありますが、1つのPurdueレベルには複数のサブネットを含めることができます。インターネットおよび企業メールにアクセスできるシステムはレベル4より深く配置すべきではなく、下位レベルのスタッフがこのデータにアクセスする必要がある場合は、レベル4マシンを割り当てる必要があります。制御システムのパッチ管理サーバーはPurdueレベル3に配置する必要があります。ICS DMZに配置すると、ファイアウォールルールが安全でない可能性があります。集約プラント履歴はPurdueレベル3に配置し、必要に応じてICS DMZ内の読み取り専用履歴に複製する必要があります。

Question 36 of 82

A security engineer is testing for SQLi vulnerabilities against an internal web application. They fill out the username field with a single quote (') and the password field with random characters. Which response would confirm to the engineer that the SQLi vulnerability is present?

- ☐ The client web browser returns the password in plaintext
- ☐ Authentication to database server is unsuccessful
- ☐ The client browser returns an "invalid username" error
- ☐ SQL error message from the backend database

全82問中36問目

セキュリティエンジニアが、社内Webアプリケーションに対してSQLインジェクションの脆弱性をテストしています。ユーザー名フィールドにはシングルクォーテーション (') を、パスワードフィールドにはランダムな文字を入力します。どの応答が、SQLインジェクションの脆弱性が存在することをエンジニアに確認させるでしょうか？

- ☐ クライアントのウェブブラウザはパスワードを平文で返します
- ☐ データベースサーバーへの認証に失敗しました
- ☐ クライアントブラウザは「無効なユーザー名」エラーを返します
- ☒ バックエンドデータベースからのSQLエラーメッセージ

✔ その通りです

SQLインジェクションとは、攻撃者がデータベースコマンド（SQLクエリ言語）を入力欄に挿入し、バックエンドデータベースにそのコマンドを実行させることができる脆弱性です。基本的なSQLインジェクションの脆弱性を検出する最も簡単な方法の一つは、入力欄にシングルクォーテーションを入力し、SQLエラーメッセージが返されるかどうかを確認することです。バックエンドデータベースからSQLエラーメッセージが返されれば、脆弱性が存在することが確認できます。

Question 37 of 82

What must an attacker identify about a wireless network in order to perform a DoS attack against it?

- ☐ The frequencies
- ☐ A previously used MAC address
- ☐ A session key
- ☐ The encryption algorithm

全82問中37問目

攻撃者が無線ネットワークに対してDoS攻撃を実行するには、そのネットワークについてどのような情報を特定する必要があるのでしょうか？

- ☒ 周波数
- ☐ 以前使用されたMACアドレス
- ☐ セッションキー
- ☐ 暗号化アルゴリズム

✔ その通りです

通信に使用される周波数を特定した攻撃者は、その周波数帯にノイズを発生させることで、DoS攻撃を実行できる。MACアドレス、アルゴリズム、セッションキーを知っていることは、DoS攻撃に特有のものではない。

Question 38 of 82

Which type of cryptographic algorithm solves the problem of secure key exchange?

- ☐ Permutation Cipher
- ☐ Substitution Cipher
- ☐ Hashing
- ☐ Asymmetric
- ☐ Symmetric

全82問中38問目

安全な鍵交換の問題を解決する暗号アルゴリズムの種類はどれですか？

- ☐ 順列暗号
- ☐ 置換暗号
- ☐ ハッシュ化
- ☒ 非対称
- ☐ 対称的

✔ その通りです

非対称アルゴリズムは公開鍵と秘密鍵のシステムを使用するため、対称アルゴリズムとは異なり、単一の鍵を共有する必要はありません。ハッシュ化は鍵を使用しませんが、元に戻せない一方関数でもあります。

置換と順列は暗号アルゴリズムで使われる手法ですが、アルゴリズムの種類ではありません。ほとんどのアルゴリズムは、目的の結果を得るために、置換、置換、およびその他の変換を組み合わせて使用します。

Question 39 of 82

What is one item that an SIS is designed to protect?

- ☐ The process
- ☐ Software
- ☐ The environment
- ☐ Equipment

SISが保護するように設計されているアイテムの1つは何ですか？

- ☒ **そのプロセス**
☐ ソフトウェア
☒ **環境**
☐ 装置

× あなたは間違っています

安全計装システム（SIS）は、安全、健康、環境への悪影響を防ぐように設計されています。SISは、安全、健康、環境を保護するために、機器やソフトウェアに関係なくプロセスを停止します。ボパール災害のようなICS事象において、環境が安全と健康に直接どのような影響を与えるかを考えてみてください。

Question 40 of 82

What is described below?

An unmanned surface vehicle (USV) is supposed to travel at 30 knots.
 If the velocity is 15 kn or less, the throttle is set to 100%.
 If the velocity is between 15 kn and 20 kn the throttle is set to 75%.
 If the velocity is between 20 kn and 25 kn the throttle is set to 50%.
 If the velocity is between 25 kn and 30 kn the throttle is set to 25%.

- ☐ Ladder logic
☐ Fuzzy logic
☐ Instruction list
☐ Sequential function block
☐ PID loop

全82問中40問目

以下に説明されている内容は何か？

An unmanned surface vehicle (USV) is supposed to travel at 30 knots.
If the velocity is 15 kn or less, the throttle is set to 100%.
If the velocity is between 15 kn and 20 kn the throttle is set to 75%.
If the velocity is between 20 kn and 25 kn the throttle is set to 50%
If the velocity is between 25 kn and 30 kn the throttle is set to 25%.

- ☐ ラダーロジック
- ☒ ファジーロジック
- ☐ 手順一覧
- ☐ シーケンシャルファンクションブロック
- ☐ PIDループ

✔ その通りです

ファジー論理は「真偽の度合い」に関係します。USVが30ノットを超えて移動している場合、それは速すぎる速度で移動していますが、論理式で単にyesまたはno:1または0を使用した場合、「どれくらい」速すぎるかはわかりません。31ノットでの移動も速すぎますし、70ノットでの移動も速すぎますが、これらの状態それぞれに対して異なる対応が必要になる場合があります。この論理式は、人が読みやすく、システムが何をすべきかを簡単に識別できます。これらの論理式は、数学的評価のためにファジー論理に変換されます。

ラダーロジックと命令リストは、プログラミング言語の一種である。

Question 41 of 82

Which type of ICS component uses the fastest polling rate?

- ☐ Programmable logic controller
- ☐ Regional SCADA
- ☐ Site SCADA
- ☐ Engineering workstation

全82問中41問目

ICSコンポーネントの中で、最も高速なポーリングレートを使用するのはどのタイプですか？

- ☒ プログラマブルロジックコントローラ
- ☐ 地域SCADA
- ☐ サイトSCADA
- ☐ エンジニアリングワークステーション

✔ その通りです

ポーリングレートは、さまざまな種類のICSコンポーネントを区別するのに役立ちます。地域SCADAは数秒から数分と最も長いポーリングレートを持ち、一方、コントローラやフィールドデバイスは1秒未満のタイミングで計測するため、最も短いポーリングレートになります。

Question 42 of 82

What is the suggested action to protect a system running a Microsoft operating system that has reached the end of extended support?

- ☐ Move to the Enterprise edition of the OS
- ☐ Logically isolate the system
- ☐ Provide automated patch updates
- ☐ Purchase and apply security hotfixes as they are released

全82問中42問目

延長サポートが終了したMicrosoftオペレーティングシステムを実行しているシステムを保護するために推奨される対策は何ですか？

- ☐ OSのエンタープライズ版に移行する
- ☒ システムを論理的に分離する
- ☐ 自動パッチアップデートを提供する
- ☐ セキュリティ修正プログラムがリリースされたら、購入して適用してください。

✔ その通りです

OSの延長サポート期間が終了し、代替OSが利用できない場合、マイクロソフトはOSを隔離することを推奨しています。延長サポート期間が終了したOSでは、その他のオプションはすべて利用できません。

Question 43 of 82

What is the Annualized Loss Expectancy (ALE) for a \$300,000 asset with an exposure factor of 25% and an Annualized Rate Occurrence of 6?

- ☐ \$450,000
- ☐ \$200,000
- ☐ \$75,000
- ☐ \$50,000

全82問中43問目

エクスポージャー係数が25%、年間発生率が6の30万ドルの資産に対する年間損失期待値（ALE）はいくらですか？

- ☒ 45万ドル
- ☐ 20万ドル
- ☐ 75,000ドル
- ☐ 5万ドル

✔ その通りです

$ALE = AV * EF * ARO$
 $ALE = \$300,000 * 25\% * 6$
 $ALE = \$75,000 * 6$
 $ARO = \$450,000$

Question 44 of 82

Which of the following is best verified through the use of hashing?

- ☐ Availability
- ☐ Integrity
- ☐ Confidentiality

全82問中44問目

ハッシュ関数を用いることで最も適切に検証できるのは、次のうちどれですか？

- ☐ 可用性
- ☒ 誠実さ
- ☐ 機密保持

☒ その通りです

ハッシュ化は、ファイルが改ざんされていないことを検証するために使用される一方関数です。ハッシュ化は元に戻せないため、データの機密性を保つ目的での送信には適していません。データがハッシュ化されると、元の形式では利用できなくなります。

Question 45 of 82

Which of the following is part of the Protect function of the NIST CSF (cybersecurity framework)?

- ☐ Providing awareness training for organizational personnel and partners
- ☐ Containing an event and eradicating it from the network
- ☐ Monitoring the network for malicious activity
- ☐ Establishing security policies and personnel responsibilities

NIST CSF（サイバーセキュリティフレームワーク）の保護機能に含まれるものはどれですか？

☒ 組織の職員およびパートナー向けに意識向上トレーニングを提供する

- ☐ イベントを封じ込め、ネットワークから排除する
- ☐ 悪意のある活動がないかネットワークを監視する
- ☐ セキュリティポリシーと担当者の責任を確立する

☒ その通りです

組織の従業員およびパートナーに対し、サイバーセキュリティ意識向上トレーニングを提供することは、保護機能の一部です。セキュリティポリシーの策定、従業員の役割と責任の明確化は、識別機能に該当します。検出機能の目的の一つは、ネットワーク上の悪意のある活動を監視することです。事象の拡散を防ぎ、ネットワークから排除する緩和策は、対応機能の一部です。

NIST CSF Protect (PR) 機能より:

意識向上とトレーニング (PR.AT) : 組織の職員およびパートナーは、サイバーセキュリティ



セキュリティ ポリシーと担当者の責任を確立することは、ID 機能 (ID) の一部です。ID.GV。

ネットワークの監視は、検出 (DE) 機能、DE.CMの一部です。

封じ込めと根絶は、回復 (RC) 機能、RC.RPの一部です。

In a typical ICS architecture, Purdue Level 3 would include which of the following functions?

- ☐ Web facing application servers and database servers
- ☐ Web facing servers and Simple Mail Transfer Protocol servers
- ☐ Application firewalls and data guard technology
- ☐ Patch management servers and site-specific application servers

全82問中46問目

一般的なICSアーキテクチャにおいて、パッチレベル3には次のうちの機能が含まれるでしょうか？

- ☐ Web向けアプリケーションサーバーとデータベースサーバー
- ☐ ウェブサーバーとシンプルメール転送プロトコルサーバー
- ☐ アプリケーションファイアウォールとデータガード技術
- ☒ パッチ管理サーバーおよびサイト固有のアプリケーションサーバー

✔ その通りです

レベル3 DMZは、インターネットDMZとは異なります。レベル3 DMZには、サービスやデータをゾーン間で共有できる機能固有のゾーンが含まれます。このゾーンに通常含まれるものには、パッチ管理サーバー、ウイルス対策管理システム、サイト固有のアプリケーションサーバー、ジャンプホスト環境、ビジネスインテリジェンスシステム、サイト固有のアプリケーションのバックエンドデータベース、開発システムなどがあります。このゾーンには、Webに面するものは含まれず、また、エンフォースメントゾーンに配置されるアプリケーションファイアウォールやデータガード技術も含まれません。

Question 47 of 82

What will the following Powershell script accomplish?

```
Get-Service | Select-Object Name, Status | Export-CSV c:\list.csv
```

- ☐ Create a CSV file containing the name and status of every system service
- ☐ Perform an HTTP GET on all entries identified in the supplied CSV file
- ☐ Prompt for an object name, and create a CSV file containing its name and status
- ☐ Generate a list of object names and statuses the operator can choose from and export those chosen to a CSV file

全82問中47問目

以下のPowerShellスクリプトは何を実行しますか？

```
Get-Service | Select-Object Name, Status | Export-CSV c:\list.csv
```

- ☒ すべてのシステムサービスの名前とステータスを含むCSVファイルを作成します。
- ☐ 提供されたCSVファイルで識別されたすべてのエントリに対してHTTP GETを実行します。
- ☐ オブジェクト名の入力を求め、その名前とステータスを含むCSVファイルを作成します。
- ☐ オペレーターが選択できるオブジェクト名とステータスのリストを生成し、選択されたものをCSVファイルにエクスポートします。

☒ その通りです

PowerShellのGet-Serviceコマンドは、システムにインストールされているすべてのサービスを識別します。その出力はSelect-Objectコマンドにパイプされ、指定されたパラメーターに従って元の出力が絞り込まれます。ここでは、Select-Objectは各サービスの名前とそのステータスのみを出力します。その出力はExport-CSVコマンドにパイプされ、PowerShellからの出力がフォーマットされて指定されたCSVファイルにエクスポートされます。

Question 48 of 82

What type of attack attempts to overrun a device's resources?

- ☐ Machine in the middle
- ☐ Session hijacking
- ☐ Denial of service
- ☐ Privilege escalation

全82問中48問目

デバイスのリソースを過剰に利用しようとする攻撃の種類はどのようなものですか？

- ☐ 中央の機械
- ☐ セッションハイジャック
- ☒ サービス拒否
- ☐ 特権の拡大

☒ その通りです

サービス拒否攻撃の手法の一つとして、デバイスのネットワーク、CPU、メモリ、その他のリソースを過剰に利用して、サービス提供能力を低下させる方法があります。中間者攻撃（MIM）は、ユーザーに信頼できないリソースを使用させることで、隠された情報を漏洩させる攻撃です。権限昇格攻撃では、設計や構成上のエラーを悪用して、追加の権限を取得します。セッションハイジャックは、正当なユーザーを強制的にログアウトさせ、そのセッションを乗っ取ることを目的としています。

Question 49 of 82

If an asset has an SLE of \$36,000 and an ALE of \$144,000 what is the applicable ARO?

- ☒ 4
- ☐ \$180,000
- ☐ \$108,000
- ☐ 1/4

全82問中49問目

資産のSLEが36,000ドル、ALEが144,000ドルの場合、適用されるAROはいくらですか？

- ☒ 4
- ☐ 18万ドル
- ☐ 10万8000ドル
- ☐ 1/4

☒ その通りです

$ALE = SLE * ARO$
 $\$144,000 = \$36,000 * ARO$
 $ARO = \$144,000 / \$36,000$
 $ARO = 4$

Question 50 of 82

If the CISO needs to determine the maximum tolerable downtime (MTD) for any given system, she will need to request which of the following?

- ☒ Business Impact Analysis
- ☐ Plan Inter-dependencies
- ☐ Disaster Recovery Plan
- ☐ Business Continuity Plan

全82問中50問目

CISOが特定のシステムにおける最大許容ダウンタイム（MTD）を決定する必要がある場合、以下のうちどれを要求する必要があるでしょうか？

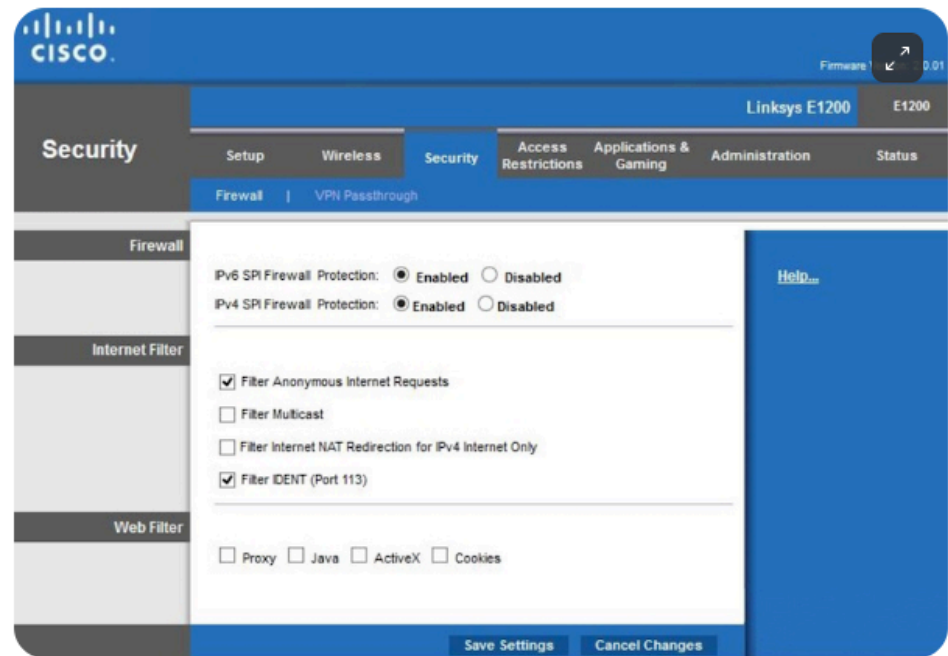
- ☒ ビジネス影響分析
- ☐ 相互依存関係を計画する
- ☐ 災害復旧計画
- ☐ 事業継続計画

☒ その通りです

事業影響度分析（BIA）は、許容可能な最大ダウンタイムを決定するために策定されます。事業継続計画および復旧計画は、その目的で使用されるものではありません。また、計画間の依存関係も、最大許容ダウンタイム（MTD）の計算には使用されません。

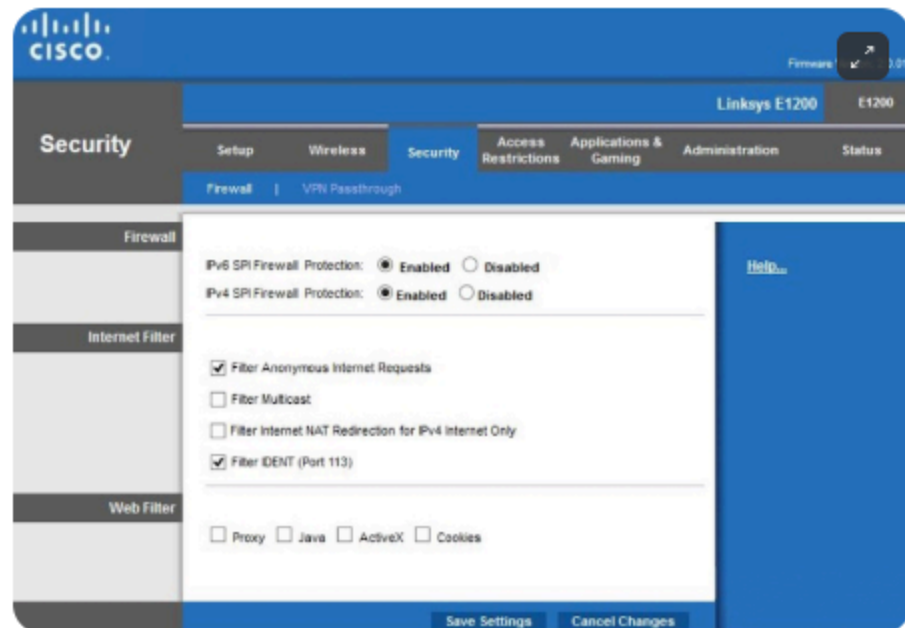
Question 51 of 82

When navigating to `http://192.168.177.1` to access the router, Max is presented with a pop-up requesting credentials. However, when he types `http://192.168.177.1/firewall.asp` into the address bar of the browser, he is presented with the web page below. What is this an example of?



- ☐ Cross Site Scripting
- ☐ Authentication Bypass
- ☐ SQL Injection
- ☐ Social Engineering

ルーターにアクセスするために `http://192.168.177.1` にアクセスすると、Max は認証情報を要求するポップアップが表示されます。しかし、ブラウザのアドレスバーに `http://192.168.177.1/firewall.asp` と入力すると、以下のウェブページが表示されます。これは何の一例でしょうか？



- ☐ クロスサイトスクリプティング
- ☒ 認証バイパス
- ☐ SQLインジェクション
- ☐ ソーシャルエンジニアリング

✔ その通りです

認証バイパスとは、ユーザーが自身の身元を検証するための制御を回避できる状態を指します。

Question 52 of 82

A penetration tester discovers an open port `tcp/23` on a legacy RTU device. What is the most likely attack for the pen tester to attempt?

- ☐ Accessing the RTU device externally over a dial-up modem
- ☐ Performing a DoS attack of the RTU over the unauthenticated administration protocol
- ☐ Sniffing or capturing clear text data and access credentials sent to or from the RTU
- ☐ Wireless access to the RTU device from a nearby parking lot

全82問中52問目

侵入テスト担当者が、旧式のRTUデバイス上でTCP/23ポートが開いていることを発見しました。侵入テスト担当者が試みる可能性が最も高い攻撃は何でしょうか？

- ☐ ダイヤルアップモデム経由でRTUデバイスに外部からアクセスする
- ☐ 認証されていない管理プロトコルを介してRTUに対するDoS攻撃を実行する
- ☒ RTUとの間で送受信される平文データやアクセス認証情報を傍受または傍受する
- ☐ 近くの駐車場からRTUデバイスへの無線アクセス

✔ その通りです

Telnet（TCP/23ポート）は、パスワードを含むすべてのTelnetトラフィックが暗号化されていないため、深刻なセキュリティリスクであり、攻撃者がデバイスをかなり制御できるようになる可能性があります。

Telnetは認証をサポートしており、Telnetが存在するからといって、デバイスへの無線アクセスやモデムアクセスが可能であることを示すものではありません。

Question 53 of 82

Which of the following Windows event logs would the analyst review in order to determine whether there is a device driver issue?

- ☐ Administrative
- ☐ Security
- ☐ Application
- ☐ System

全82問中53問目

アナリストがデバイスドライバの問題の有無を判断するために確認するWindowsイベントログは次のうちどれですか？

- ☐ 管理
- ☐ 安全
- ☐ 応用
- ☒ システム

✔ その通りです

デバイスドライバの問題はシステムログに記録されます。管理者が最初に確認すべき場所としては、そこが論理的に適切でしょう。

Question 54 of 82

Which communication method offers the longest range for connecting remote sites to a central control center?

- ☐ CDMA
- ☐ 802.11n
- ☐ Microwave
- ☐ VSAT

全82問中54問目

遠隔地と中央管制センターを接続する際に、最も長い通信距離を提供する通信方式はどれですか？

- ☐ CDMA
- ☐ 802.11n
- ☐ 電子レンジ
- ☒ VSAT

✔ その通りです

海上石油プラットフォームのような遠隔地では、機器を企業の中央制御センターに接続する唯一の方法として、衛星（VSAT、BGANなど）によるアップリンクが選択肢となる場合がある。

Question 55 of 82

Which of the following mechanisms is designed for centrally collecting records of local events from field devices and many other systems?

- ☐ Kerberos
- ☐ syslog
- ☐ iptables
- ☐ netlog

全82問中55問目

以下のメカニズムのうち、現場機器やその他の多くのシステムからローカルイベントの記録を一元的に収集するように設計されているのはどれですか？

- ☐ ケルベロス
- ☒ syslog
- ☐ iptables
- ☐ ネットログ

✔ その通りです

syslogプロトコルは、組み込みフィールドデバイスとサーバーやワークステーションなどの従来のITインフラストラクチャの両方で広くサポートされており、ネットワーク経由でログデータを収集し、中央の場所で分析することができます。Kerberosプロトコルは、認証、認可、アカウントिंग（AAA）の集中管理に使用され（そのため、アクセス要求の失敗をログに記録して報告できます）、リモートデバイスに保存されている既存のログデータやイベントデータを収集する機能はありません。「netlog」オプションは架空のログ記録メカニズムであり、ベルギーに拠点を置く同名のソーシャルネットワーキングサイトとは一切関係ありません。最後に、iptablesはLinuxシステムのファイアウォールメカニズムであり、ログ記録/イベント管理システムではありません。

Question 56 of 82

You are being asked to write a utility script that runs once a month and retrieves several files from the /etc directory on all of your Linux-based embedded devices for centralized analysis. Which IT-related process does this script support?

- ☐ Configuration monitoring
- ☐ Log collection and audit
- ☐ Baseline image testing
- ☐ Patch management

全82問中56問目

あなたは、毎月1回実行され、すべてのLinuxベースの組み込みデバイスの/etcディレクトリから複数のファイルを取得して一元的に分析するユーティリティスクリプトを作成するよう依頼されています。このスクリプトは、どのIT関連プロセスをサポートしますか？

- ☒ 構成監視
- ☐ ログ収集と監査
- ☐ ベースライン画像検査
- ☐ パッチ管理

✔ その通りです

Linux では、/etc ディレクトリは設定ファイル用に予約されており、バイナリやログデータは含まれていないため、問題のスクリプトはデバイスの現在の設定のみを取得できます。設定監視プロセスの一環として、このデータは分析され、現在の設定が期待値に準拠しており、展開以降変更されていないことが確認されます。ログ収集とパッチ管理を参照する2つの回答は、/etcには設定ファイルしか含まれていないため誤りです。「ベースラインイメージのテスト」という回答も、質問文ではデバイスから中央の場所への読み取り専用のデータフローについて説明されており、ベースラインデータがデバイスにプッシュされることについては何も言及されていないため誤りです。

Question 57 of 82

Which of the following demonstrates the recommended level of detail for a mobile device encryption policy statement?

- ☐ Data at rest on mobile devices must be secured
- ☐ The following steps shall be used to enable full disk encryption
- ☐ Approved third party disk encryption can be used on mobile devices running the Linux operating system
- ☐ Mobile devices should be protected with BitLocker full disk encryption

全82問中57問目

モバイルデバイスの暗号化ポリシー記述書において推奨される詳細レベルを示すのは、次のうちどれですか？

- ☒ **モバイルデバイスに保存されているデータは保護されなければならない**
- ☐ フルディスク暗号化を有効にするには、以下の手順を使用します。
- ☐ 承認されたサードパーティ製のディスク暗号化は、Linuxオペレーティングシステムを実行しているモバイルデバイスで使用できます。
- ☐ モバイルデバイスはBitLockerによるフルディスク暗号化で保護されるべきである。

☒ **その通りです**

ポリシーには、どのように行うべきかではなく、何を行うべきかを記述する高レベルの記述が含まれます。「モバイルデバイスに保存されているデータは保護されなければならない」という記述は、高レベルのポリシー記述の一例であり、標準、ガイドライン、手順といった他のすべての選択肢によって裏付けられています。

Question 58 of 82

An attack that modifies data in an ICS is a violation of which information security concept?

- ☐ Integrity
- ☐ Non-repudiation
- ☐ Availability
- ☐ Confidentiality

全82問中58問目

ICS内のデータを改ざんする攻撃は、どの情報セキュリティ概念に違反するでしょうか？

- ☒ **誠実さ**
- ☐ 否認禁止
- ☐ 可用性
- ☐ 機密保持

☒ **その通りです**

完全性制御は情報の改ざんを防止するため、予期せずデータを変更できる攻撃は完全性に対する攻撃となります。機密性とは、権限のある者のみがデータにアクセスできるようにすることです。可用性とは、必要なときにデータにアクセスできることを意味します。否認防止とは、ある人物が何らかの行動をとったことを否定できないようにすることです。

Question 59 of 82

Which layer of the OSI model does UDP belong to?

- ☐ Layer 3 - Network
- ☐ Layer 2 - Data Link
- ☐ Layer 4 - Transport
- ☐ Layer 5 - Session

全82問中59問目

UDPはOSIモデルのどの層に属しますか？

- ☐ レイヤー3-ネットワーク
- ☐ レイヤー2-データリンク
- ☒ レイヤー4-トランスポート
- ☐ レイヤー5-セッション

✔ その通りです

TCPと同様に、UDPはトランスポート層で動作します。IPはネットワーク層で動作し、イーサネットなどのプロトコルはデータリンク層で動作します。NetBIOSやRPCなどのプロトコルはセッション層で定義されています。

Question 60 of 82

Please examine the risk analysis values noted below. What is the calculated Annualized Loss Expectancy for the particular risk?

- ASSET VALUE: \$100
- SINGLE LOSS EXPECTANCY: \$60
- LIKELIHOOD: 0.15
- FREQUENCY: 5

- ☐ \$300
- ☐ \$75
- ☐ \$15
- ☐ \$45

全82問中60問目

下記のリスク分析値をご確認ください。当該リスクに対する年間損失期待値はいくらですか？

- 資産価値：100ドル
- 1回の損失予想額：60ドル
- 可能性:0.15
- 頻度：5

- ☐ 300ドル
- ☐ 75ドル
- ☐ 15ドル
- ☒ 45ドル

✔ その通りです

年間損失期待値とは、特定の脅威によって生じる年間予想財務損失額のことで、この値は、3つの異なる計算によって算出されます。

- 単一損失期待値 = 資産価値 × 損失率
- 年間発生率 = 可能性 × 頻度
- 年間損失期待値 = 単一損失期待値 × 年間発生率

上記の値を用いてこれらの式を使用すると、以下に示すように年間損失期待値を計算できます。

- 単一損失期待値 = 60ドル（既知）
- 年間発生率 = 0.75（発生確率（0.15）× 発生頻度（5））
- 年間損失期待値 = 45ドル（単一損失期待値（60ドル）× 年間発生率（0.75））

Question 61 of 82

What can an attacker analyze to find cryptographic keys being transmitted by hardware?

- ☐ Fuzzy logic
- ☐ Clock timing
- ☐ FET transistors
- ☐ Entropy levels

全82問中61問目

攻撃者は、ハードウェアによって送信される暗号鍵を特定するために、どのような情報を分析できるのでしょうか？

- ☒ ファジーロジック
- ☐ クロックタイミング
- ☐ FETトランジスタ
- ☒ エントロピーレベル

✖ あなたは間違っています

エントロピーの急上昇は、暗号鍵が送信されていることを示している可能性がある。

Question 62 of 82

How could an administrator apply security policies to Windows machines that are not part of an Active Directory domain?

- ☐ Delivering a template through Group Policy
- ☐ Delivering a template with secedit.exe
- ☐ Using Windows Server Update Services (WSUS)

全82問中62問目

管理者は、Active Directoryドメインに参加していないWindowsマシンにセキュリティポリシーをどのように適用できるのでしょうか？

- ☐ グループポリシーを通じてテンプレートを配信する
- ☒ **secedit.exe を使用したテンプレートの配信**
- ☐ Windows Server Update Services (WSUS) を使用する

☒ その通りです

secedit.exe は、Active Directory ドメインに参加していないマシンのセキュリティポリシーを更新できるコマンドラインツールです。スクリプト機能も備えているため、ネットワーク上の数百台のマシンのポリシーを更新するために使用できます。scw.exe は、古い Windows サーバーでマシンごとにセキュリティポリシーを構成するのに役立ちます。グループポリシーを使用してセキュリティテンプレートを展開するには、対象のマシンがドメインに参加している必要があります。WSUS は、Active Directory ドメインに参加しているシステムのパッチを一元管理するためのツールです。MECM も WSUS と同様にパッチを一元管理するために使用されますが、システムパフォーマンスの監視やインベントリ管理などの機能強化が施されています。

Question 63 of 82

Which of the following is the type of document you would use to communicate to field engineers in detail how the firmware is to be upgraded on a particular RTU?

- ☐ Procedure
- ☐ Guideline
- ☐ Policy
- ☐ Standard

特定のRTUのファームウェアをどのようにアップグレードするかを現場のエンジニアに詳細に説明するために使用する文書の種類は、次のうちどれですか？

ba140299-2b3f-4b4e-adeb-8b2a1cb6f463 (14266005)

- ☒ 手順
- ☐ ガイドライン
- ☐ ポリシー
- ☒ 標準

✖ あなたは間違っています

手順とは、特定のタスクを繰り返し実行するための段階的な指示です。RTUのファームウェアのアップグレードのようなタスクは、その重要性から手順を作成するのに最適です。ポリシーは、より高レベルの記述です。ガイドラインは、ポリシーと手順の中間に位置し、より漠然とした一般的なガイダンスを提供します。標準とは、組織やデバイスに固有のものではないものです。

An internal penetration test finds a WEP-protected wireless network being used for remote administrative access on a main network switch via TCP port 23. Is this considered a network security finding?

- ba140299-2b3f-4b4e-adeb-8b2a1cb6f463 (14266005)
- ☐ Yes, an attacker can access the wireless without a password and brute-force a telnet login
 - ☐ No, while WEP is weaker than WPA, it provides adequate protection for SSH traffic
 - ☐ Yes, an attacker can break the wireless key and intercept plaintext telnet credentials
 - ☐ No, WEP protects the wireless network and SSH remote access is considered secure

内部侵入テストの結果、WEPで保護された無線ネットワークがTCPポート23を介してメインネットワークスイッチへのリモート管理アクセスに使用されていることが判明しました。これはネットワークセキュリティ上の問題とみなされますか？

- ☐ はい、攻撃者はパスワードなしで無線LANにアクセスし、Telnetログインをブルートフォース攻撃で試みることができます。
- ☐ いいえ、WEPはWPAよりも脆弱ですが、SSHトラフィックに対して十分な保護を提供します。
- ☒ はい、攻撃者は無線キーを破り、平文のTelnet認証情報を傍受することができます。
- ☐ いいえ、WEPは無線ネットワークを保護し、SSHリモートアクセスは安全であると考えられています。

✔ その通りです

これはセキュリティ上の問題です。攻撃者が使用されている WEP キーを簡単に復元し、無線ネットワークを通過するすべての平文トラフィックを傍受できてしまうためです。TCP ポート 23 は、平文リモート アクセス プロトコルである telnet で使用され、正当なユーザーがこのネットワーク経由でログインすると、攻撃者は管理者ログインとパスワードを傍受できてしまいます。WEP キーは簡単に復元できますが、ネットワークにアクセスするにはパスワード (WEP キー) が必要です。SSH トラフィックに関する 2 つの選択肢は、TCP ポート 23 が telnet で使用され、SSH は TCP ポート 22 で実行されるため、誤りです。

Which of the following contains the logic and parameters for Programmable Logic Controllers (PLCs)?

- ☐ Front End Processor
- ☐ Project Files
- ☐ Human Machine Interface
- ☐ Historian

全82問中65問目

次のうち、プログラマブルロジックコントローラ（PLC）のロジックとパラメータが含まれているのはどれですか？

- ☐ フロントエンドプロセッサ
- ☒ プロジェクトファイル
- ☐ ヒューマンマシンインターフェース
- ☐ 歴史家

✔ その通りです

PLC が実行するタスクはハードコーディングされていません。名前が示すように、PLC の機能はプログラムで設定できます。エンジニアリングワークステーションによく保存されているプロジェクト ファイルには、制御システム、ネットワークアーキテクチャ、構成、および PLC のロジックとパラメータの詳細が含まれています。そのため、攻撃者にとって格好の標的となります。ヒューマンマシンインターフェースは、オペレータにデータを提供しますが、自動化されたプロセスのロジックは含まれていません。ヒストリアンにはイベントログが含まれており、多くの場合 SQL データベースに保存されます。フロントエンドプロセッサは、RTU (リモートターミナルユニット) と管理システム間の通信を監視します。

Question 66 of 82

A firm reviews the results of a disaster recovery test where customers were unaware of an alternative support website. Which of the following does the firm need to address in the BCP/DR process?

- ☐ Lack of prioritization
- ☐ Lack of plan ownership
- ☐ Lack of security controls
- ☐ Lack of communication

全82問中66問目

ある企業が、顧客が代替サポートウェブサイトの存在を知らなかったという災害復旧テストの結果を検証しています。企業は、BCP/DRプロセスにおいて、次のうちどれに対処する必要がありますか？

- ☐ 優先順位付けの欠如
- ☐ 計画に対する所有権の欠如
- ☐ セキュリティ管理の欠如
- ☒ コミュニケーション不足

✔ その通りです

コミュニケーション不足とは、組織のあらゆる関係者（従業員、契約社員、ベンダー、ビジネスパートナー、顧客、株主など）との明確かつ正確なコミュニケーションの必要性を考慮していないことを意味します。これは広報計画にも当てはまります。

Question 67 of 82

Jeff has just installed a new Windows based workstation into the domain on his company's DCS network. A screen saver pops up every five minutes and Jeff does not want the screensaver active on this workstation. Jeff calls up the local policy on the workstation and sees that there is an active screen saver policy. Jeff tries to update the policy, but the button is greyed out and won't allow updates. What is most likely preventing Jeff from disabling the screen saver on this workstation?

- ☐ There is a domain based policy being applied to the workstation that overrides the local security policy.
- ☐ The DCS vendor has applied custom program code to prevent unauthorized tampering with local policy.
- ☐ No policies are being applied because the workstation has the wrong refresh settings applied.
- ☐ Jeff's account is in the local administrator's group, but not included in the local policy group.

全82問中67問目

ジェフは、会社のDCSネットワーク上のドメインに、Windowsベースの新しいワークステーションをインストールしました。5分ごとにスクリーンセーバーがポップアップ表示されるのですが、ジェフはこのワークステーションでスクリーンセーバーを有効にたくありません。ワークステーションのローカルポリシーを確認すると、スクリーンセーバーポリシーが有効になっていることがわかりました。ジェフはポリシーを更新しようとしませんが、ボタンがグレー表示になっていて更新できません。ジェフがこのワークステーションでスクリーンセーバーを無効にできない原因として最も考えられるのは何でしょうか？

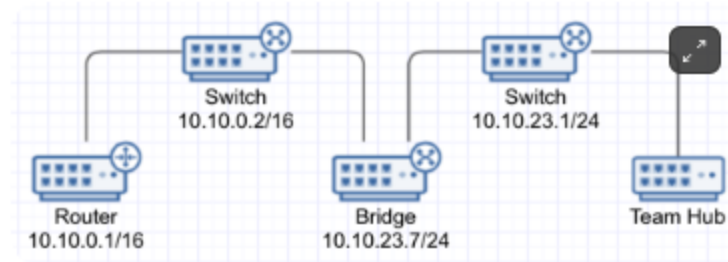
- ☒ ワークステーションには、ローカルセキュリティポリシーを上書きするドメインベースのポリシーが適用されています。
- ☒ DCSベンダーは、ローカルポリシーへの不正な改ざんを防止するために、カスタムプログラムコードを適用しました。
- ☐ ワークステーションの更新設定が間違っているため、ポリシーが適用されていません。
- ☐ ジェフのアカウントはローカル管理者グループには含まれていますが、ローカルポリシーグループには含まれていません。

✖ あなたは間違っています

ドメインベースのポリシー設定は、ローカルのセキュリティポリシー設定を上書きできます。ローカル管理者アカウントがあれば、セキュリティポリシー設定を変更できます。DCSベンダーは推奨ポリシー設定を提供することが多いですが、OSを変更するような非公開のカスタムプログラムコードは提供しません。更新設定は、設定変更や新しい設定の適用を制限しません。

Question 68 of 82

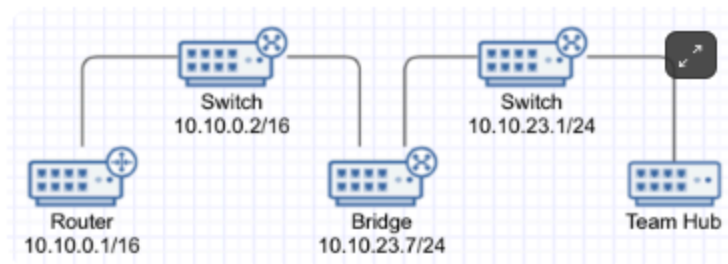
Observe the devices below; which network device will drop Layer 2 broadcast traffic?



- ☐ Router
- ☐ Switch
- ☐ Hub
- ☐ Bridge

全82問中68問目

以下のデバイスを観察してください。どのネットワークデバイスがレイヤ2ブロードキャストトラフィックをドロップしますか？



- ☒ ルーター
- ☐ スイッチ
- ☐ ハブ
- ☐ 橋

✓ その通りです

ルーターはレイヤー3で動作し、パケット転送時にIPアドレスを参照します。ルーターはデフォルトではMACレベル（レイヤー2）のトラフィックをすべて破棄します。スイッチとブリッジはMACレベルの情報を使用してトラフィックを切り替えます。ハブは、1つのポートで受信したトラフィックを、稼働中のすべてのポートに単純に中継します。

Question 69 of 82

Which level of the Purdue Enterprise Reference Architecture (PERA) groups systems that support site-wide operations?

- ☐ 3
- ☐ 5
- ☐ 4
- ☐ 2

全82問中69問目

Purdue Enterprise Reference Architecture (PERA) のどのレベルで、サイト全体の運用をサポートするシステムがグループ化されていますか？

☒ 3
baf02992f3f4b4eadeb8b2a1cb6f463 (14266005)

- ☐ 5
☐ 4
☐ 2

☒ その通りです

パデューモデルでは、システムを0から4までの5つの異なるレベルに分割することを提案しています。レベル0は最も低いレベルで、物理的なプロセスを表し、そのグループのプロセスを構成する直接的なセンサーとアクチュエータが含まれます。レベル1には、そのグループのプロセスのコントローラが含まれます。レベル2には、各グループのプロセスに固有のローカル監視システムが含まれます。プロセスグループの上には、工場全体または地域全体のレベル3があり、そのサイトまたはその地域のすべてのプロセスグループを制御する監視システムが含まれます。レベル3には、運用をサポートするシステムで構成されますが、プロセスのリアルタイム実行には直接関与しない運用サポートも含まれます。レベル4は、ICSに関連する組織のビジネス面を表します。パデューモデルの現代的な進化では、多くの場合、すべての企業ビジネスユニットに対するエンタープライズサポートを表すレベル5が含まれます。

Question 70 of 82

Who has the ultimate responsibility to ensure an ICS meets security requirements in the field?

☐ Integrators
baf02992f3f4b4eadeb8b2a1cb6f463 (14266005)

- ☐ Asset owners
☐ Government entities
☐ Vendor partners

全82問中70問目

現場においてICSがセキュリティ要件を満たしていることを保証する最終的な責任は誰にあるのでしょうか？

☐ インテグレーター
baf02992f3f4b4eadeb8b2a1cb6f463 (14266005)

- ☒ 資産所有者
☐ 政府機関
☐ ベンダーパートナー

☒ その通りです

資産所有者／運用者は、効率的で政府規制に適合するシステムを設計・構築するために、ベンダーやシステムインテグレーターと協力する必要があります。近年、セキュリティは世間の注目を集めるようになり、政府規制当局による監視も強化されています。現在、資産所有者／運用者は、運用するシステムにセキュリティが組み込まれるようにする責任を負っています。

Question 71 of 82

What can you derive from the following screen capture?

```
root@bt:~# sha1sum file5.txt
6476df3aac780622368173fe6e768a2edc3932c8 file5.txt
root@bt:~# sha1sum file6.txt
6476df3aac780622368173fe6e768a2edc3932c8 file6.txt
root@bt:~#
```

- ☐ file5.txt and file6.txt have been encrypted with the key 6476df3aac780622368173fe6e768a2edc3932c8
- ☐ The contents of file5.txt and file6.txt have been encrypted with the sha1 algorithm
- ☐ file5.txt and file6.txt have been signed with the key 6476df3aac780622368173fe6e768a2edc3932c8
- ☐ The contents of file5.txt are exactly the same as file6.txt

全82問中71問目

次のスクリーンショットから何がわかりますか？

```
root@bt:~# sha1sum file5.txt
6476df3aac780622368173fe6e768a2edc3932c8 file5.txt
root@bt:~# sha1sum file6.txt
6476df3aac780622368173fe6e768a2edc3932c8 file6.txt
root@bt:~#
```

- ☐ file5.txtとfile6.txtは、キー6476df3aac780622368173fe6e768a2edc3932c8で暗号化されています。
- ☐ file5.txtとfile6.txtの内容はsha1 アルゴリズムで暗号化されています。
- ☐ file5.txtとfile6.txtは、キー6476df3aac780622368173fe6e768a2edc3932c8で署名されています。
- ☒ file5.txtの内容はfile6.txtと全く同じです。

✔ その通りです

2つのSHA1ハッシュが同じであれば、ファイルの内容は同一であることを意味します。SHA1はファイルを暗号化せず、公開鍵や秘密鍵も使用しません。

Question 72 of 82

The head of the Ackme IT department sent a directive stating that all company communication must use TLS in order to prevent third parties from modifying data without Ackme's knowledge. Which part of the C-I-A model is the head of IT concerned with?

- ☒ Integrity
- ☐ Encryption
- ☐ Availability
- ☐ Confidentiality

全82問中72問目

Ackme社のIT部門責任者は、第三者がAckme社の許可なくデータを改ざんすることを防ぐため、すべての社内通信にTLSを使用するよう指示を出しました。IT部門責任者はCIAモデルのどの部分に関心を持っているのでしょうか？

☒ 誠実さ

- ☐ 暗号化
- ☐ 可用性
- ☐ 機密保持

☒ その通りです

データの完全性とは、データが不正に改ざんされないことがないという保証によって定義される。

Question 73 of 82

According to the DHS suggested patch decision tree, what should a security team do after it is determined that a vulnerability affects their ICS?

- ☐ Analyze the vulnerability footprint
- ☐ Determine if the operational needs are greater than the risk
- ☐ Analyze the impact to the business needs and operations
- ☐ Determine if there is a work-around available

全82問中73問目

国土安全保障省が提案するパッチ適用決定ツリーによると、セキュリティチームは脆弱性が産業制御システム（ICS）に影響を与えることが判明した場合、どのような対応を取るべきでしょうか？

- ☐ 脆弱性の痕跡を分析する
- ☐ 運用上のニーズがリスクを上回るかどうかを判断する
- ☐ ビジネスニーズと業務への影響を分析する
- ☒ 回避策があるかどうかを確認する

☒ その通りです

チームは、脆弱性がICSに影響を与えるかどうかを判断する必要があります。影響がない場合は、通常どおり運用を継続できますが、影響がある場合は、回避策が利用可能かどうかを判断する必要があります。回避策が利用可能な場合は、予定されているアップデート期間が利用可能になるまで、その回避策を使用できます。回避策がない場合は、運用上のニーズがリスクよりも大きいかどうかをチームが判断する必要があります。この判断には、ビジネスニーズと運用への影響、および脆弱性のフットプリントを分析する必要があります（脆弱性がICSに影響を与えるかどうかを判断した後の2つの判断）。

Question 74 of 82

What is a recommended guideline to follow when setting up a secure ICS network architecture?

- ☐ Place simple proxies in the ICS DMZ to keep them separate from systems in the control network
- ☐ Move any onsite servers that communicate with the cloud for control systems to the ICS DMZ
- ☐ Use the same jump hosts for employees and vendors
- ☐ Do not set up a trust between Active Directory domains on the control network and the Enterprise network

全82問中74問目

安全なICSネットワークアーキテクチャを構築する際に推奨されるガイドラインは何か？

- ☐ シンプルなプロキシをICS DMZに配置して、制御ネットワーク内のシステムから分離します。
- ☐ 制御システムのためにクラウドと通信するオンプレミスサーバーをすべてICS DMZに移動します。
- ☐ 従業員とベンダーには同じジャンプホストを使用する
- ☒ **コントロールネットワークとエンタープライズネットワーク上のActive Directoryドメイン間で信頼関係を構築しないでください。**

☒ その通りです

安全な ICS ネットワーク アーキテクチャを構築するための推奨サイバー セキュリティ ガイドラインには、次のものが含まれます。1) 単純なプロキシは脆弱性を盲目的に通過させるため使用を避ける、2) エンタープライズとの信頼関係を持たない制御ネットワーク用の別の AD ドメインを設定する、3) 制御ネットワークのクラウドに接続するオンサイトサーバーを ICS DMZ に配置せず、別の DMZ に配置する、4) リモートで制御ネットワークにアクセスする各従業員またはベンダーは、それぞれのニーズに応じて異なるジャンプ ホストを使用する。

Question 75 of 82

What is an example of deterrence as a physical security defense?

- ☐ Hidden cameras
- ☐ Audible alarms
- ☐ Physical walk-down
- ☐ Bright lighting

全82問中75問目

物理的な安全保障対策としての抑止力の例を挙げてください。

- ☐ 隠しカメラ
- ☐ 可聴アラーム
- ☐ 物理的な徒歩移動
- ☒ 明るい照明

✔ その通りです

物理的なセキュリティ対策には、抑止、遅延、検知、対応が含まれます。抑止とは、攻撃者が攻撃を試みる可能性を低減するあらゆるセキュリティ機能を指します。例としては、有刺鉄線付きの高いフェンス、目に見えるカメラ、明るい照明、目立つ警備員などが挙げられます。侵入を施設職員に知らせる可聴アラームは、検知の一例です。完全に効果的な抑止策であれば、可聴アラームの使用は不要になります。物理的な巡回点検とは、経験豊富な現場職員が、何か紛失または異常がないかを確認するために行う検査です。

Question 76 of 82

Use PowerShell to display all WMI objects and select strings that contain **user** in them. How many results are returned?

Hint: the output can be piped to "Measure-Object" to easily find the count.

View VM

- ☒ 13
- ☐ 20
- ☐ 25
- ☐ 91
- ☐ 72
- ☐ 94
- ☐ 18
- ☐ 47
- ☐ 48
- ☐ 60

全82問中76問目

PowerShellを使用してすべてのWMIオブジェクトを表示し、**user**それらに含まれる文字列を選択します。結果はいくつ返されますか？

ヒント：出力を「Measure-Object」にパイプすることで、簡単にカウントを取得できます。

VMを表示

- ☐ 13
- ☐ 20
- ☐ 25
- ☐ 91
- ☐ 72
- ☐ 94
- ☐ 18
- ☐ 47
- ☐ 48
- ☐ 60

```
PS C:\Users\student> Get-WmiObject -List | Select-String user | Measure-Object

Count      : 20
Average    :
Sum        :
Maximum    :
Minimum    :
Property   :
```

全82問中76問目

PowerShellを使用してすべてのWMIオブジェクトを表示し、**user**それらに含まれる文字列を選択します。結果はいくつ返されますか？

ヒント：出力を「Measure-Object」にパイプすることで、簡単にカウントを取得できます。

- ☐ 13
- ☒ 20
- ☐ 25
- ☐ 91
- ☐ 72
- ☐ 94
- ☐ 18
- ☐ 47
- ☐ 48
- ☐ 60

✔ その通りです

Get-WmiObject -List | Select-String user | Measure-Object

Question 77 of 82

Examine the control sheet found on the Desktop in the following directory structure:

Velocio PLC\MyChemicalMixer\MyChemicalMixer.vio.

Which of the following is an unsigned 16-bit integer tag?

View VM

- ☐ Bobcat
baf43299-2f31-4b4e-adeb-8b2a1cb6f463 (14266005)
- ☐ Seahorse
- ☐ Elk
- ☐ Horse
- ☐ Gazelle
- ☐ Bear
- ☐ Zebra
- ☐ Antelope
- ☐ Unicorn
- ☐ Moose

VELOCIO FLOW RUNNER

Tags

Input / Output	Name	Is Array	Array Size		Used	Remote Writable	Modbus	
Input bit	State	☐		☒	☒	☒	☒	Delete
Input i16	vFactoryPage	☐		☒	☐	☒	☐	Delete
Input Float	Zebra	☐		☒	☐	☐	☐	Delete
Output bit		☐		☐	☐	☐	☐	
Output ui16		☐		☐	☐	☐	☐	

Register

bit

ui8

i16

ui16

i32

Float

デスクトップにある以下のディレクトリ構造内のコントロールシートを確認してくださいVelocio PLC\MyChemicalMixer\MyChemicalMixer.vio。

次のうち、符号なし16ビット整数タグはどれですか？

- ☐ ポブキャット
- ☐ タツノオトシゴ
- ☐ ヘラジカ
- ☐ 馬
- ☐ ガゼル
- ☐ クマ
- ☒ シマウマ
- ☐ アンテロープ
- ☐ ユニコーン
- ☐ ムース

☒ その通りです

Velocioでは、上部のアイコンバーから「タグ」アイコンを選択します。

「ui16」ボタンを選択してください。

Zebraは「ui16」に分類されるため、符号なし整数となります。

From the GIAC directory on the Desktop, open gicsp.pcap in Wireshark and filter for USB Capture data. Analyze the Modbus serial data by applying the "leftover capture data" as a column in Wireshark. In packet 34, what unit is information being requested from? Use the protocol description in the image.

Unit ID	Read Function	Start Address	Num to Read	CRC
1 byte	1 byte	2 bytes	2 bytes	2 bytes
2 hex chars	2 hex chars	4 hex chars	4 hex chars	4 hex chars

View VM

- ☐ 2
- ☐ 1
- ☐ 7
- ☐ 4
- ☐ 6
- ☐ 9
- ☐ 3
- ☐ 8
- ☐ 5
- ☐ 10

usb.capdata

No.	Time	Source	Destination	Protocol	Length	Leftover Capture Data	Info
26	0.550849	host	2.7.1	USB	72	010200020004d809	URB_BULK out
28	0.551306	2.7.2	host	USB	70	01020100a188	URB_BULK in
30	0.553880	host	2.7.1	USB	72	0101000c0003bc08	URB_BULK out
32	0.554431	2.7.2	host	USB	70	01010102d049	URB_BULK in
34	0.556779	host	2.7.1	USB	72	01030003000575c9	URB_BULK out
36	0.557219	2.7.2	host	USB	79	01030a000000000000000000024b6	URB_BULK in
76	2.638156	host	2.7.1	USB	72	010200020004d809	URB_BULK out
78	2.638679	2.7.2	host	USB	70	01020100a188	URB_BULK in
80	2.641665	host	2.7.1	USB	72	0101000c0003bc08	URB_BULK out
82	2.642117	2.7.2	host	USB	70	01010104504b	URB_BULK in
84	2.644541	host	2.7.1	USB	72	01030003000575c9	URB_BULK out

URB sec: 1644948335

URB usec: 259330

URB status: Operation now in progress (-EINPROGRESS) (-115)

URB length [bytes]: 8

Data length [bytes]: 8

[\[Response in: 35\]](#)

[bInterfaceClass: CDC-Data (0x0a)]

Unused Setup Header

Interval: 0

Start frame: 0

> Copy of Transfer Flags: 0x00000004, No transfer DMA map

Number of ISO descriptors: 0

Leftover Capture Data: 01030003000575c9

全82問中78問目

デスクトップ上のGIACディレクトリから、Wiresharkでgicsp.pcapを開き、USBキャプチャデータでフィルタリングします。Wiresharkで「残りのキャプチャデータ」を列として適用し、Modbusシリアルデータを分析します。パケット34では、どのユニットから情報が要求されていますか？画像内のプロトコルの説明を参照してください。

Unit ID	Read Function	Start Address	Num to Read	CRC
1 byte	1 byte	2 bytes	2 bytes	2 bytes
2 hex chars	2 hex chars	4 hex chars	4 hex chars	4 hex chars

☐ 2 baf40295-2f3f-4b4e-adeb-8b2a1cb6f463 (14266005)

- ☒ 1
- ☐ 7
- ☐ 4
- ☐ 6
- ☐ 9
- ☐ 3
- ☐ 8
- ☐ 5
- ☐ 10

☒ その通りです

このパケットの Modbus データは で始まります 0x01。これはユニット番号 1 に対応します。

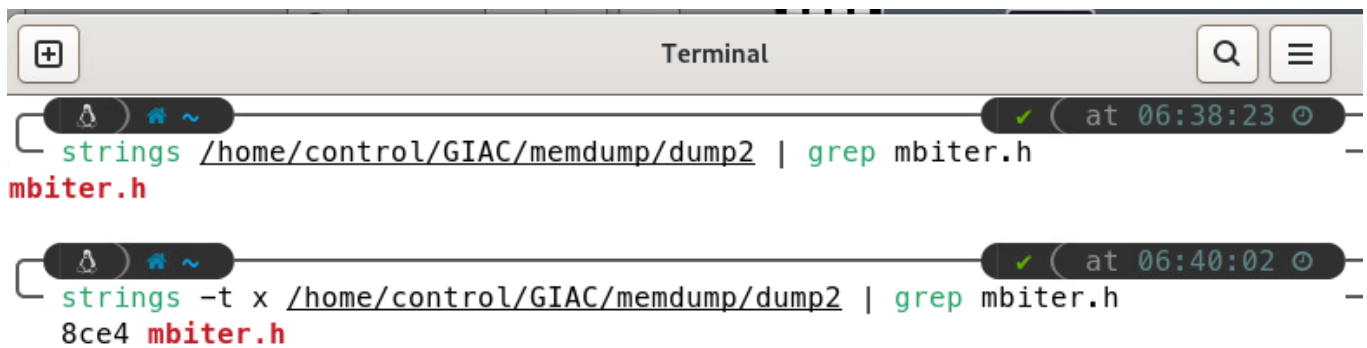
Question 79 of 82

Examine ~/GIAC/memdump/dump2. At which offset is mbiter.h referenced?

Hint: Try piping to **grep** to minimize output.

View VM

- ☐ 7ee5
- ☐ 0e12
- ☐ 259b
- ☐ 965d
- ☐ 1aec
- ☐ 20fc
- ☐ 1f0e
- ☐ 8ce0
- ☐ 0bc1
- ☐ 4600



```
Terminal
[+] [Search] [Menu]
[Terminal Icon] [Home Icon] [~] [✓] ( at 06:38:23 [Close] )
strings /home/control/GIAC/memdump/dump2 | grep mbiter.h
mbiter.h

[Terminal Icon] [Home Icon] [~] [✓] ( at 06:40:02 [Close] )
strings -t x /home/control/GIAC/memdump/dump2 | grep mbiter.h
8ce4 mbiter.h
```

~/GIAC/memdump/dump2 を調べてください。mbiter.h はどのオフセットで参照されていますか？

ヒント：grep 出力を最小限に抑えるために、パイプ処理を試してみてください。

- ☐ 7ee5
- ☐ 0e12
- ☐ 259b
- ☐ 965d
- ☐ 1aec
- ☐ 20fc
- ☐ 1f0e
- ☒ 8ce0
- ☐ 0bc1
- ☐ 4600

✔ その通りです

xxd は、データの ASCII 表現と、データが見つかったオフセットを出力します。

Open Firefox, navigate to localhost, and click on "Login" under the Main Menu on the left side of the page. The "Name:" field is vulnerable to SQL injection. Use SQL injection to log in as the user coltrane. What are the three words that are now displayed near the top of the left hand column?

HINT: Spaces before *and after* SQL comments are required. Also be sure to enter at least one character in the password field.

[View VM](#)

- ☐ Response, Presense, Extent
- ☐ Feather, Jewel, Command
- ☐ Mobile, Steward, Muscle
- ☐ Reform, Training, Access
- ☐ Stable, Future, Moral
- ☐ Treaty, Blackmail, Impress
- ☐ Coffee, Humor, Outlook
- ☐ Onion, Pumpkin, Gallon
- ☐ Diet, Reward, Knowledge
- ☐ Virtue, Chapter, Divide

localhost/index.php?page=

+

localhost/index.php?page=login.php

Welcome to Dojo Control's Shift Logger!

Not logged in

Main Menu

[Home](#)[Register](#)[Login](#)

Pentester Help

[About](#)[Toggle Hints](#)[Vuln List](#)[Credits](#)[Reset DB](#)

Login

If you do not have an account, [Register](#)

Bad user name or password!

Enter your username and password:

Name:

coltrane' --

Password:

•

Submit

Dojo-Control Home

+

localhost/index.php

Welcome to Dojo Control's Shift Logger!

You are logged in as coltrane

Main Menu

[Home](#)[Response](#)[Presense](#)[Extent](#)

User Info

[Enter Shift Log](#)[View Shift Logs](#)[Reading Room](#)[Play Snake](#)[Logout](#)

User Utilities

[Ping Asset](#)[DNS Lookup](#)[Browser Info](#)

Dojo Control

Here at Dojo Control Industries we pride ourselves on the quality and quantity of the products that we make and sell. We have been doing business since 1976, and are in over 30 differer countries.

Our CEO, Kevin Flynn is second to none when it comes to eliminating his rivals. He is the hand and you are the weapon. Keep yourself sharp!

If you are a new operator, please use the links to the left to register a new account.

Question 80 of 82

Open Firefox, navigate to localhost, and click on "Login" under the Main Menu on the left side of the page. The "Name:" field is vulnerable to SQL injection. Use SQL injection to log in as the user coltrane. What are the three words that are now displayed near the top of the left hand column?

HINT: Spaces before *and after* SQL comments are required. Also be sure to enter at least one character in the password field.

[View VM](#)

Response, Presense, Extent

- ☐ Feather, Jewel, Command
- ☐ Mobile, Steward, Muscle
- ☐ Reform, Training, Access
- ☐ Stable, Future, Moral
- ☐ Treaty, Blackmail, Impress
- ☐ Coffee, Humor, Outlook
- ☐ Onion, Pumpkin, Gallon
- ☐ Diet, Reward, Knowledge
- ☐ Virtue, Chapter, Divide

全82問中80問目

Firefoxを開き、localhostにアクセスして、ページの左側にあるメインメニューの「ログイン」をクリックします。「名前:」フィールドはSQLインジェクションの脆弱性があります。SQLインジェクションを使用して、ユーザーcoltraneとしてログインしてください。左側の列の上部付近に表示される3つの単語は何ですか？

ヒント：SQLコメントの前後にはスペースが必要です。また、パスワード欄には少なくとも1文字を入力してください。

反応、存在、範囲

- ☐ 羽根、宝石、命令
- ☐ モバイル、スチュワード、マッスル
- ☐ 改革、研修、アクセス
- ☐ 安定、未来、道徳
- ☐ 条約、脅迫、強制
- ☐ コーヒー、ユーモア、展望
- ☐ 玉ねぎ、かぼちゃ、ガロン
- ☐ 食事、報酬、知識
- ☐ 美德、章、分割

その通りです

名前欄に名前を入力しcoltrane' -- 、パスワード欄には任意の文字列を入力してください。すると、魔法の言葉が表示されます。

Question 81 of 82

Examine ~/GIAC/plantemonium.pcap using Wireshark. How many Modbus directors are represented in this packet capture?

[View VM](#)

- ☐ 56
- ☐ 20
- ☐ 4
- ☐ 1
- ☐ 72
- ☐ 10
- ☐ 2
- ☐ 5
- ☐ 3
- ☐ 73

Wireshark · Endpoints · plantemonium.pcap										
Ethernet · 4		IPv4 · 5		IPv6	TCP · 23		UDP			
Address ▾	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Country	City	AS Number	AS Organization
10.21.22.10	35	2,395	18	1,242	17	1,153	—	—	—	—
10.21.22.22	1	69	0	0	1	69	—	—	—	—
10.21.22.23	24	1,616	10	660	14	956	—	—	—	—
10.21.22.24	15	1,011	8	528	7	483	—	—	—	—
10.21.22.253	7	495	5	363	2	132	—	—	—	—

Wiresharkを使用して~/GIAC/plantemonium.pcapを調べてください。このパケットキャプチャには、いくつのModbusディレクターが含まれていますか？

- ☐ 56
baf4c299-2f3f-4b4e-adeb-8b2a1cb6f463 (14266005)
- ☐ 20
- ☐ 4
- ☐ 1
- ☐ 72
- ☐ 10
- ☒ 2
- ☒ 5
- ☐ 3
- ☐ 73

✖ あなたは間違っています

Wiresharkで「modbus」をフィルタリングする

統計 > 会話

「表示フィルターを制限」チェックボックスをオンにする

IPv4を選択

「アドレスA」列は接続を開始するアセットを表しており、これらはディレクターにあたります。このリストの「アドレスA」列には、2つの異なるIPアドレスが含まれています。

✖ You are incorrect

Filter for 'modbus' in Wireshark

Statistics > Conversations

Check the "Limit to display filter" check box\

Select IPv4

Column "Address A" represents assets initiating a connection, so they would be the director. This list has 2 distinct IP addresses in the Address A column.

Question 82 of 82

What are the last four digits of the hash created when using openssl with the sha512 digest and an hmac of "picard" on ~/GIAC/film?

View VM

- ☐ 7a06
- ☐ 1c77
- ☐ 7b6b
- ☐ a77f
- ☐ 1a43
- ☐ 07af
- ☐ 903e
- ☐ 81f5
- ☐ 3132
- ☐ 2614

```
openssl dgst -sha512 -hmac "picard" /home/control/GIAC/film
HMAC-SHA512(/home/control/GIAC/film)= ee65d35c44fa7cf402fcd8bf62d05f1af5ece00349
5cd3b9ff4d4c2cddbfc53c1871117f7557e9b80ab904dacd0679b05731772990aaafc568aabcb99a
f71a43
```

全82問中82問目

~/GIAC/film に対して、sha512ダイジェストとhmac「picard」を使用してopensslで生成されたハッシュの最後の4桁は何ですか？

- ☐ 7a06
- ☐ 1c77
- ☐ 7b6b
- ☐ a77f
- ☒ 1a43
- ☐ 07af
- ☐ 903e
- ☐ 81f5
- ☐ 3132
- ☐ 2614

✔ その通りです

この結果を得るには、コマンドラインでopensslを使用するか、CyberChefを使用できます。

オプション: dgst -sha512 -hmac "picard"

終了しました

実技試験 合格

得点：82 % (合格)



GICSP模擬試験

試験問題

合計：82

回答済み：82

ステータス：合格

あなたのスコア：82 %

最低合格点：71 %

完了日：2026年5月29日

CyberLive認証バイパス



CyberLiveバイナリファイル解析



サイバーライブ暗号化



CyberLiveエンドポイントのセキュリティ強化、ベースライン、ログ



CyberLiveフィールドバスプロトコル分析



CyberLive産業交通分析



エンドポイントの強化と保護



ICSコンポーネントとアーキテクチャ



ICSの概要と概念



ICSプログラムおよび政策開発



情報収集と脅威モデリング



PERAレベル0および1の技術概要と侵害



PERAレベル2および3の技術概要とリスク



プロトコル、コミュニケーション、そして妥協



リスクベースの災害復旧およびインシデント対応



無線技術とその限界

